COLABERRY · DEMO FOR SOLICITATION 90MC26R0004

SSS Modernization Demo

A working platform for the Selective Service System's registrant services: online accounts, exemption eligibility, case management with appeals, and automatic compliance checks on every decision.

Demo site sss-demo-frontend.onrender.com Status as of **October 31, 2026**

All 46 stories addressed **45 working in the demo; AWS GovCloud written as code, waiting on approval**

> Everything described here is demonstrated on a synthetic demo deployment; none of it is operating in production. Synthetic data only. The exemption types shown (A senior, B income, C hardship) are illustrative rules built to exercise the workflow. They are not Selective Service policy.

WHAT THE APP IS FOR

One place to register, apply, decide and prove it

The Selective Service System keeps the national registry that federal law requires nearly every man living in the United States to join between the ages of 18 and 25. Registration status follows people for years: it can affect eligibility for federal jobs and some state programs, so registrants, agencies and staff all need fast, accurate answers.

This demo modernizes the business systems behind that work: online registration and registrant records, profile updates with compliance checks, exemption and appeal case management, compliance verification, and reporting. It shows the user experience and the controls together, so evaluators can see how the proposed approach works in practice rather than on paper.

Registrants and applicants

Create an account, keep their profile current, see which exemptions they qualify for and why, apply, follow every step of their case, and appeal a denial.

Case managers

Start from a work list of their own cases, take ownership, decide with a stated reason, keep internal notes, and export case lists for reporting.

Compliance, administrators and leadership

See whether decisions follow the rules, review any that do not, and search two audit logs. Administrators see the whole operation and set access rules; leadership sees program numbers with no applicant data.

CHALLENGES IT SOLVES

The problems this platform addresses

Registrants can't see where they stand

People need to register, update their details and know the status of a request without calling or mailing anyone.

Self-service accounts, a profile with a built-in compliance check, eligibility results with a plain-language reason for each, a case timeline and in-app notifications at every status change.

IN THE DEMO

Decisions that are hard to explain or challenge

Applicants deserve to know why they were refused and how to respond.

Rules produce a status and a reason for every exemption type. A denial cannot be saved without a written reason, which the applicant sees, and a denied applicant can appeal from the same page.

IN THE DEMO

No proof that each decision followed the rules Oversight needs evidence for every decision, not a sample.	Every approval and denial is checked against 8 decision controls the moment it is made. A failure opens a review that only a different case manager can resolve, with a written justification. A dashboard tracks the rate against a 99% target.	IN THE DEMO
Sensitive personal data at risk Social Security numbers and case records must be protected and only seen by the right people.	SSNs are stored only as one-way hashes, never shown back or logged, and entered in a masked field. Every page of the API declares who may use it, an automated test fails the build if any route lacks its access check, and every read, export and refusal goes into a write-once security audit log.	IN THE DEMO
Case work spread across inboxes and spreadsheets Staff need one queue with clear ownership.	A shared case queue with status counts, filters, assignment, internal notes, document links and CSV export that never includes SSNs.	IN THE DEMO
Screens that show stale data Dashboards and case pages must show current information within seconds of a change.	Every profile save, eligibility check, application and case change is timed until the next request can read it. Staff see each data type against a 30-second target for 95% of updates, an alert when one falls behind, and the slowest updates.	IN THE DEMO
Screens some people cannot use Every screen must work for people using assistive technology (Section 508).	Every page is checked against WCAG 2.1 AA, which includes Section 508, signed out, as an applicant and as a case manager. It works by keyboard with a skip link, screen readers hear each field by its name with its errors, contrast is at least 4.5:1, nothing is lost at 320 pixels, a session warns before it ends, and applications are confirmed before they are sent.	IN THE DEMO

A stolen password is enough to sign in Staff and registrants need a second proof of identity.	Two-step verification with an authenticator app: after the password, a 6-digit code that changes every 30 seconds, never works twice and gets five tries per sign-in. Every step is audited without the key or the code.	IN THE DEMO
Managers and leaders can't see the work Each role needs the numbers that match its job, and no more.	Case managers get a work list with what is waiting on them and what is overdue. Administrators see every case by status and type, team performance and system health. Leadership sees approval rate, processing time and bottlenecks, with no applicant data.	IN THE DEMO
Access rules buried in code Who may see or do what must be explicit, testable and changeable without a release.	Open Policy Agent decides every API request before any route runs, from role, resource, action and owner. Administrators change the rules on a page, with a reason, and every change and refusal is audited.	IN THE DEMO
AI answers no one can check An assistant may only say what the policy says, and people, not the assistant, must decide a person's case.	Claude answers only from the policy documents, with a citation on every statement, and each answer is checked before it is shown. Questions about a person's own case, failed checks and reported answers go to a case manager.	IN THE DEMO
AI and systems that drift unnoticed Quality, fairness and service levels must be watched after go-live, with alerts and evidence.	Answer quality is tracked daily and re-tested against a baseline; fairness is tested by changing only details that must not matter; every request is traced, and objectives are checked every minute with alerts and a runbook.	IN THE DEMO
Hosting that meets federal requirements Production must run on FedRAMP-authorized cloud with multi-factor sign-in.	The demo runs on commercial hosting today. AWS GovCloud infrastructure (STORY-004) waits on approval. Multi-factor sign-in is already in the demo (scene 13).	PLANNED

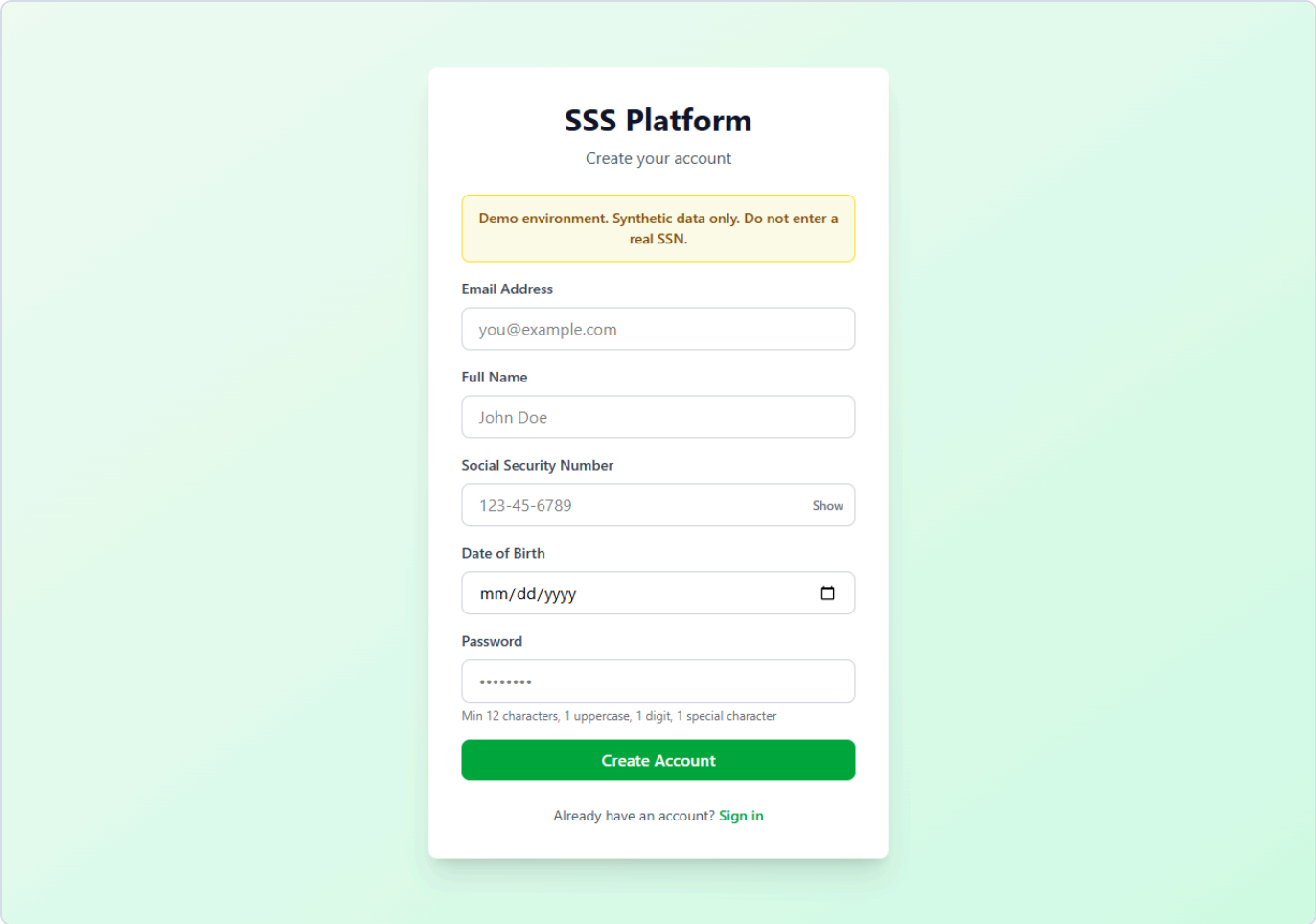
DEMO WALKTHROUGH

Twenty-seven scenes, about thirty minutes

SCENE 1 ·

A registrant creates an account

- The banner reminds everyone this is synthetic data. The SSN field is masked, with a Show toggle.
- Passwords need 12 characters with a capital, a digit and a symbol. The SSN is hashed before it is stored.



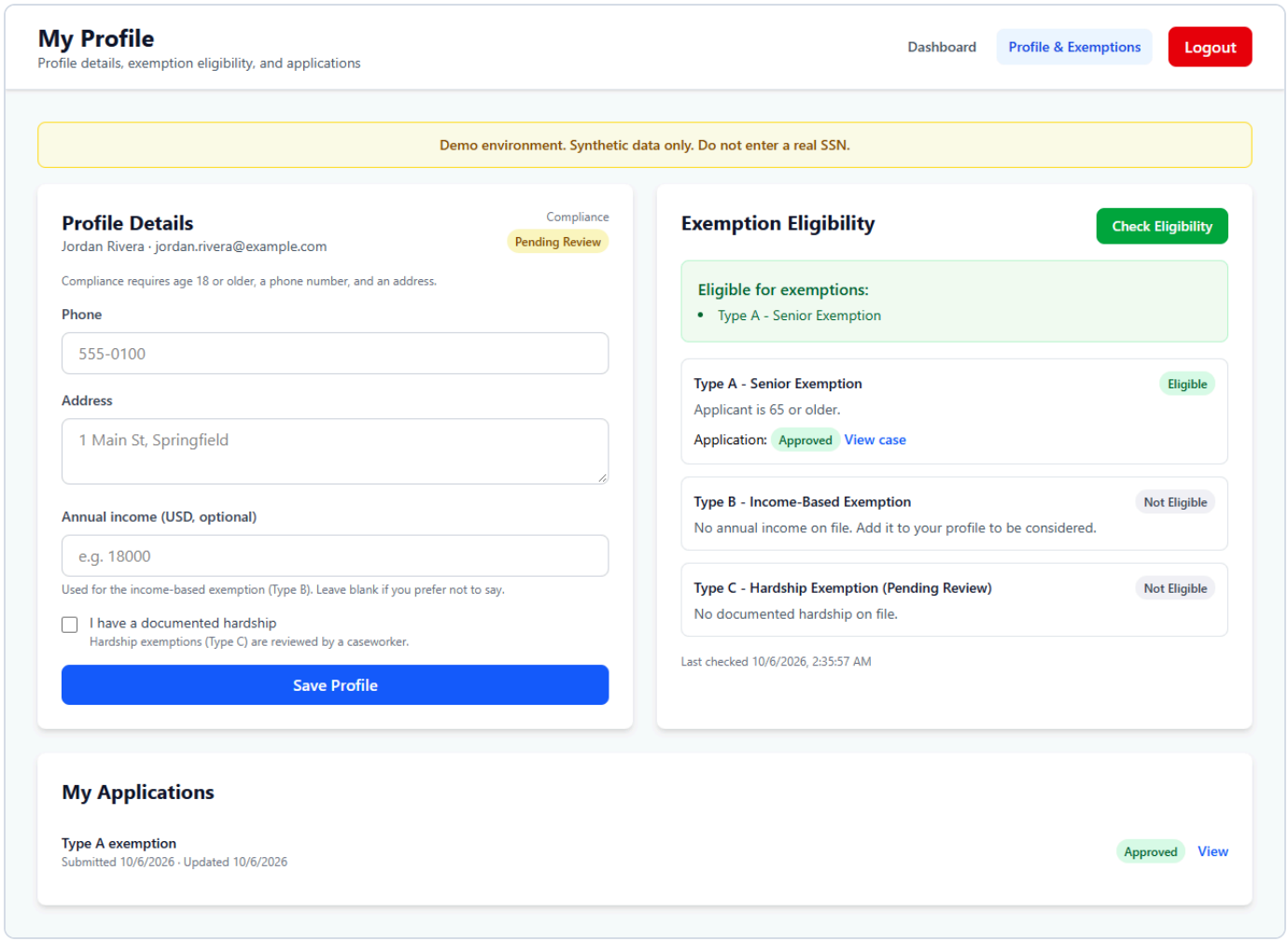
Registration, with the synthetic-data banner and masked SSN entry.

SCENE 2 ·

Eligibility, with a reason for every result

- The profile page checks the registrant's record (18 or older, phone, address) and shows what is missing.

- Each exemption type returns Eligible, Pending Review or Not Eligible with a plain-language

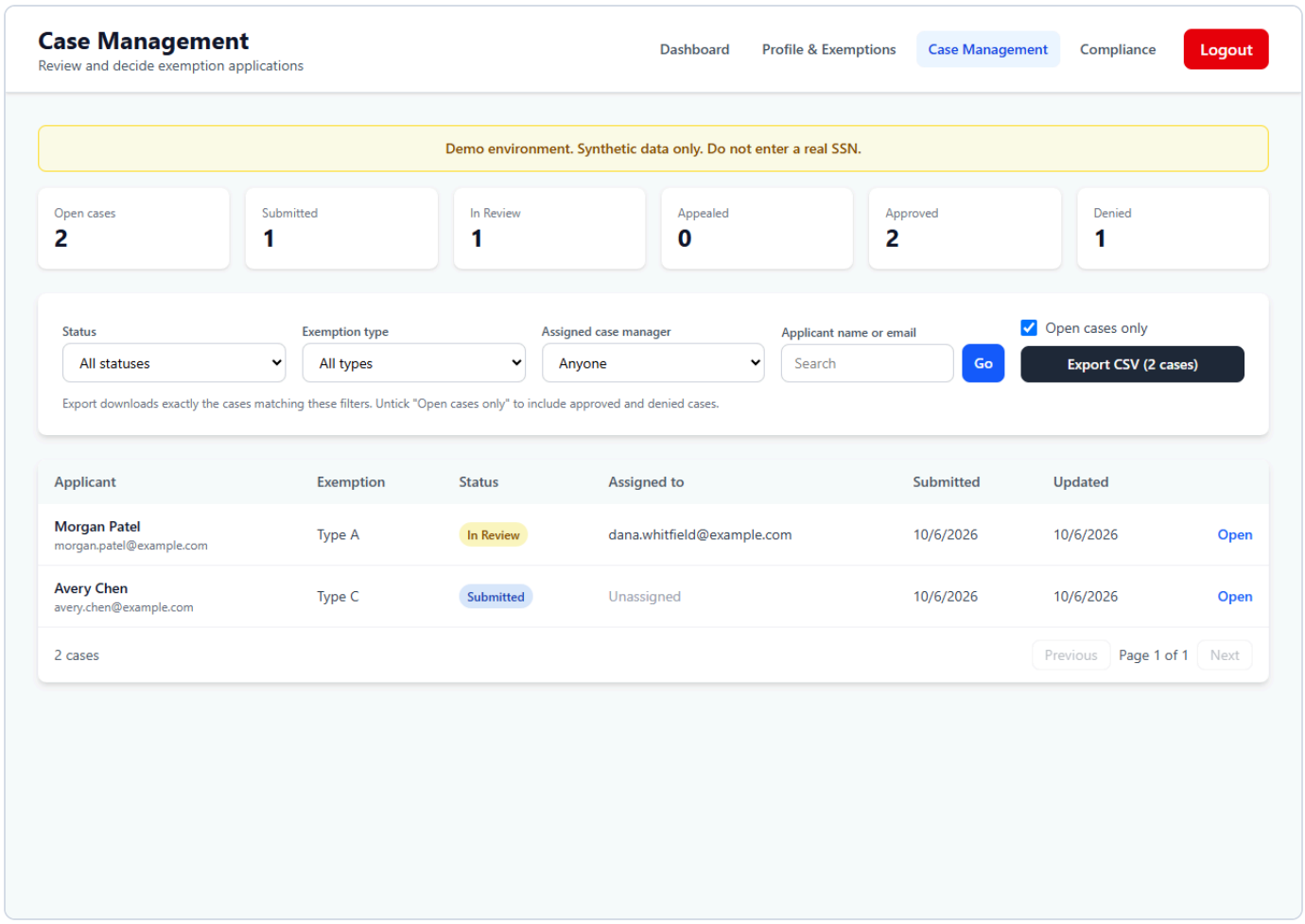


Jordan Rivera qualifies for Type A because the applicant is 65 or older; the other types explain why not.

SCENE 3 ·

Case managers work one queue

- Counts by status, filters by status, type, case manager and applicant, and an export of exactly the filtered cases.
- Each case shows who owns it. Unassigned work is visible at a glance.

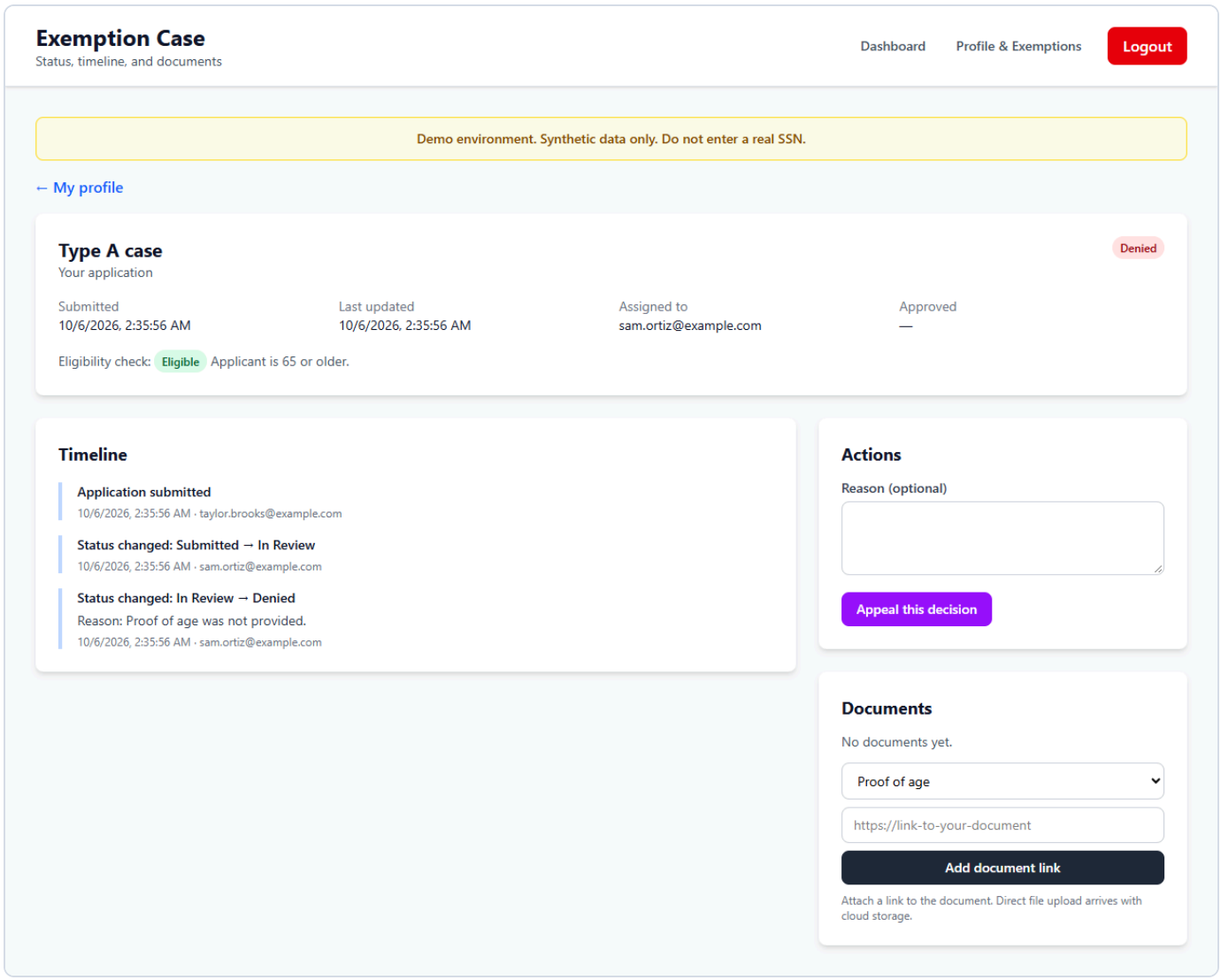


Two open applications: one in review with Dana Whitfield, one newly submitted and unassigned.

SCENE 4 ·

A denial always carries its reason

- The case manager cannot deny without a reason, and the applicant sees it on the timeline.
- The applicant can appeal from the same page, which sends the case back for review.

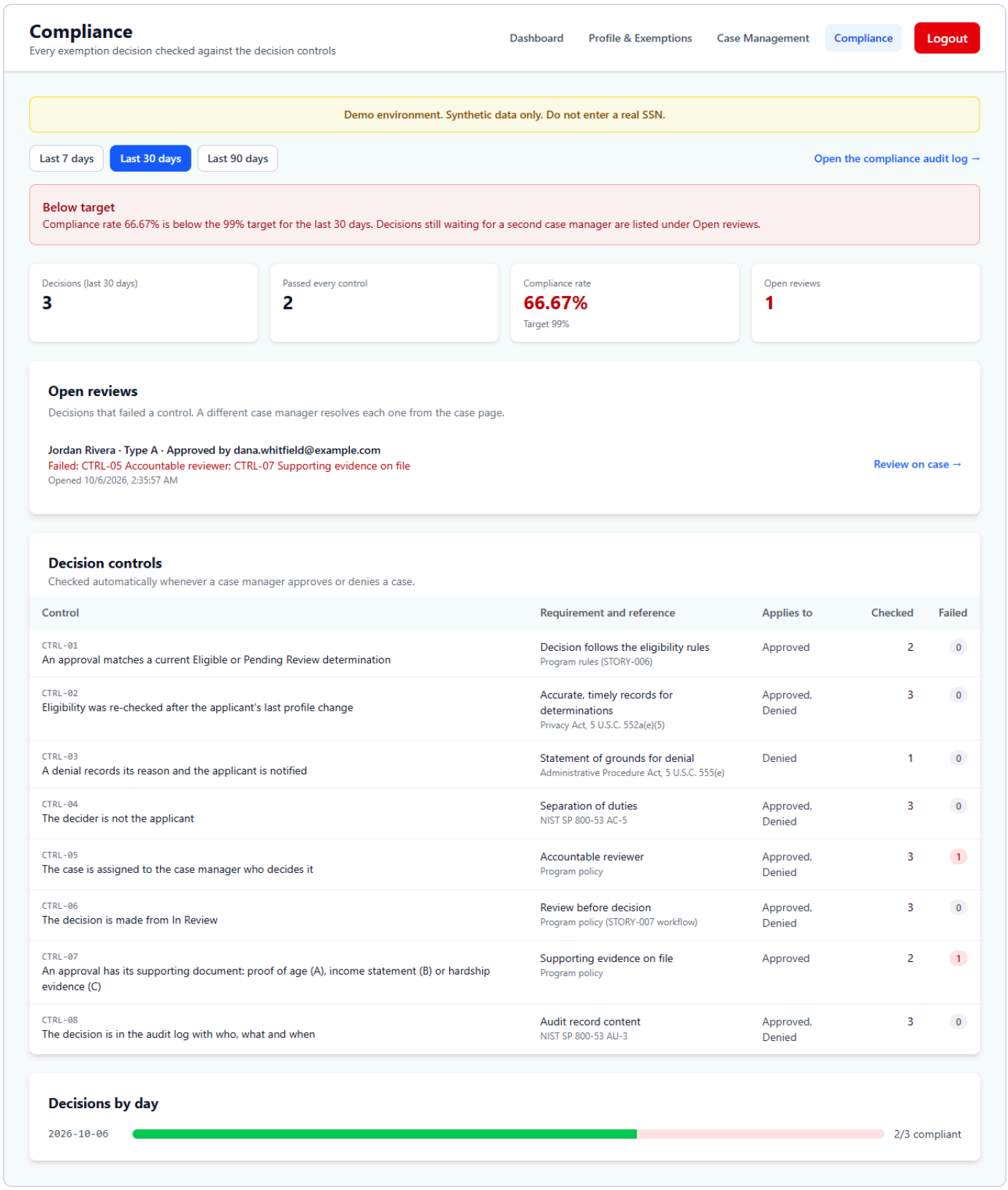


Taylor Brooks sees "Proof of age was not provided." and can appeal.

SCENE 5 ·

Every decision is checked automatically

- When a case is approved or denied, 8 controls run at once: eligibility basis, a fresh eligibility check, reason and notice, separation of duties, ownership, review before decision, required document and an audit entry.
- Here one of three decisions failed two controls, so the rate is 66.67% against the 99% target and the dashboard raises an alert.

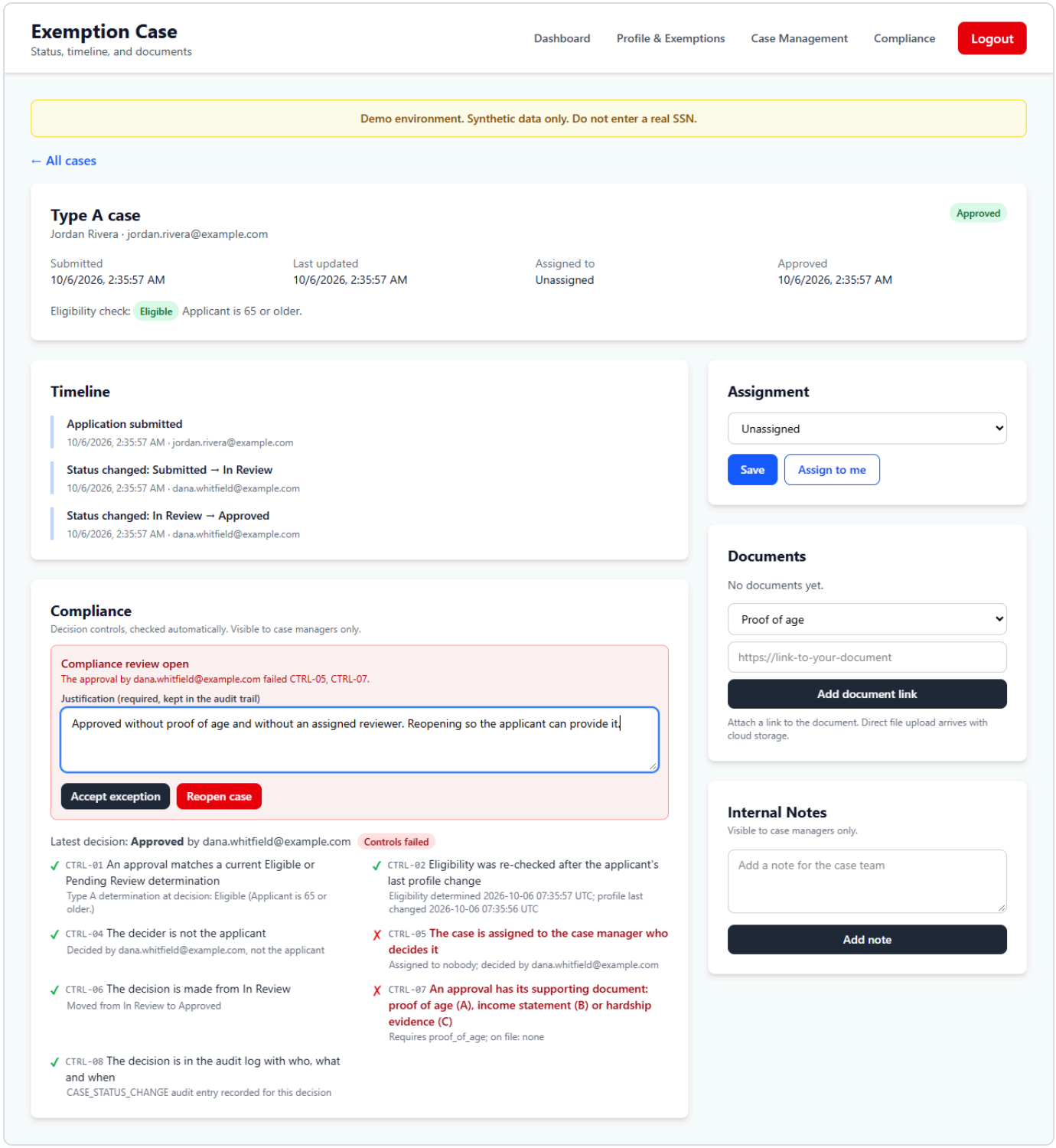


The compliance dashboard: rate against target, open reviews, and failures per control with their legal or policy basis.

SCENE 6 ·

A second case manager reviews the failure

- The case was approved while unassigned and without proof of age. The case page lists each control with its evidence.
- The manager who decided cannot clear their own review. A different manager must write a justification, then either accept the exception (logged as an override) or reopen the case, which notifies the applicant.

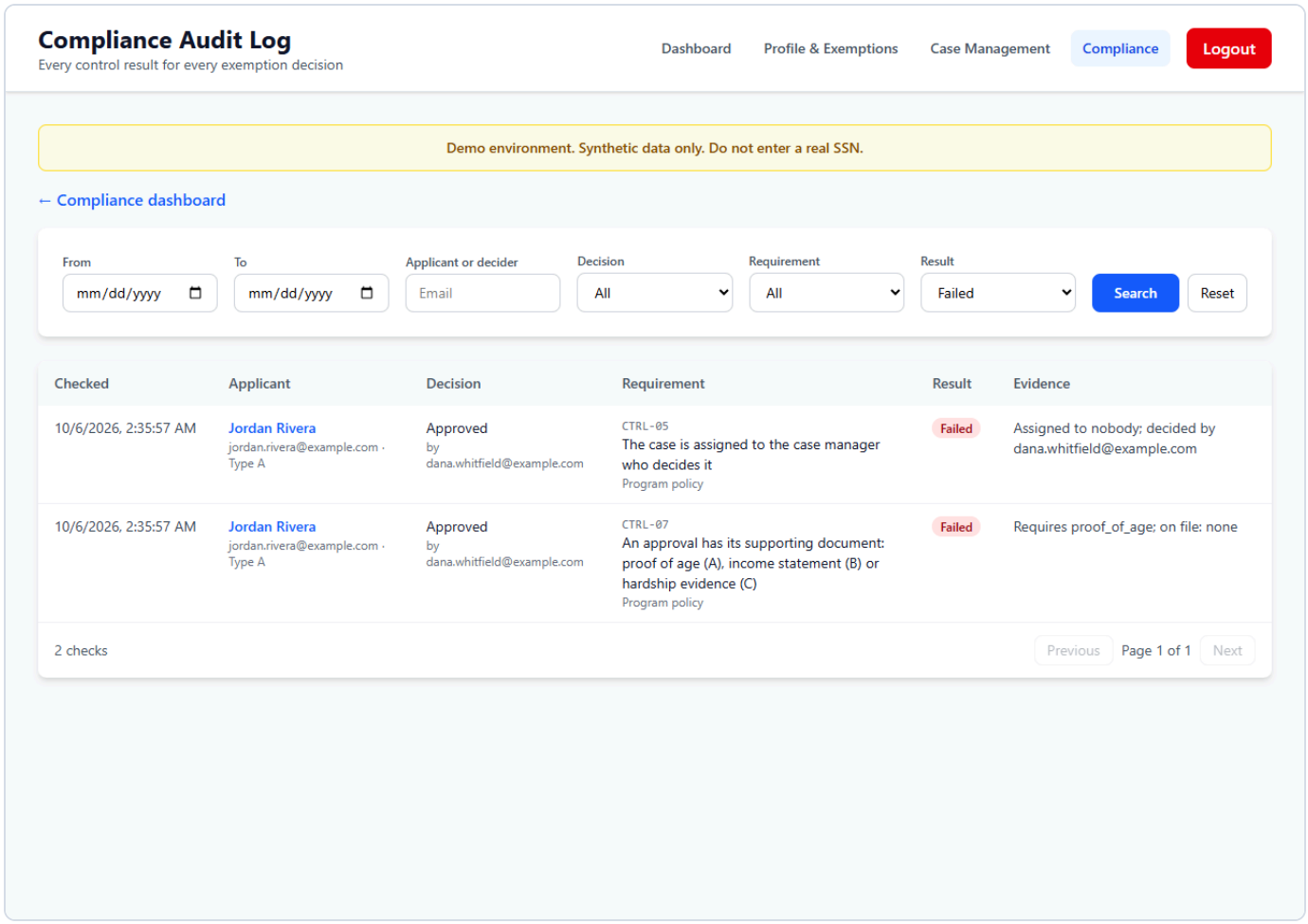


Sam Ortiz reviews Dana Whitfield's approval and reopens it with a written reason.

SCENE 7 ·

Auditors search every control result

- Filter by date range, applicant or decider, decision, control and result.
- Failed decisions stay in the record even after review, so the history cannot be tidied up afterwards.

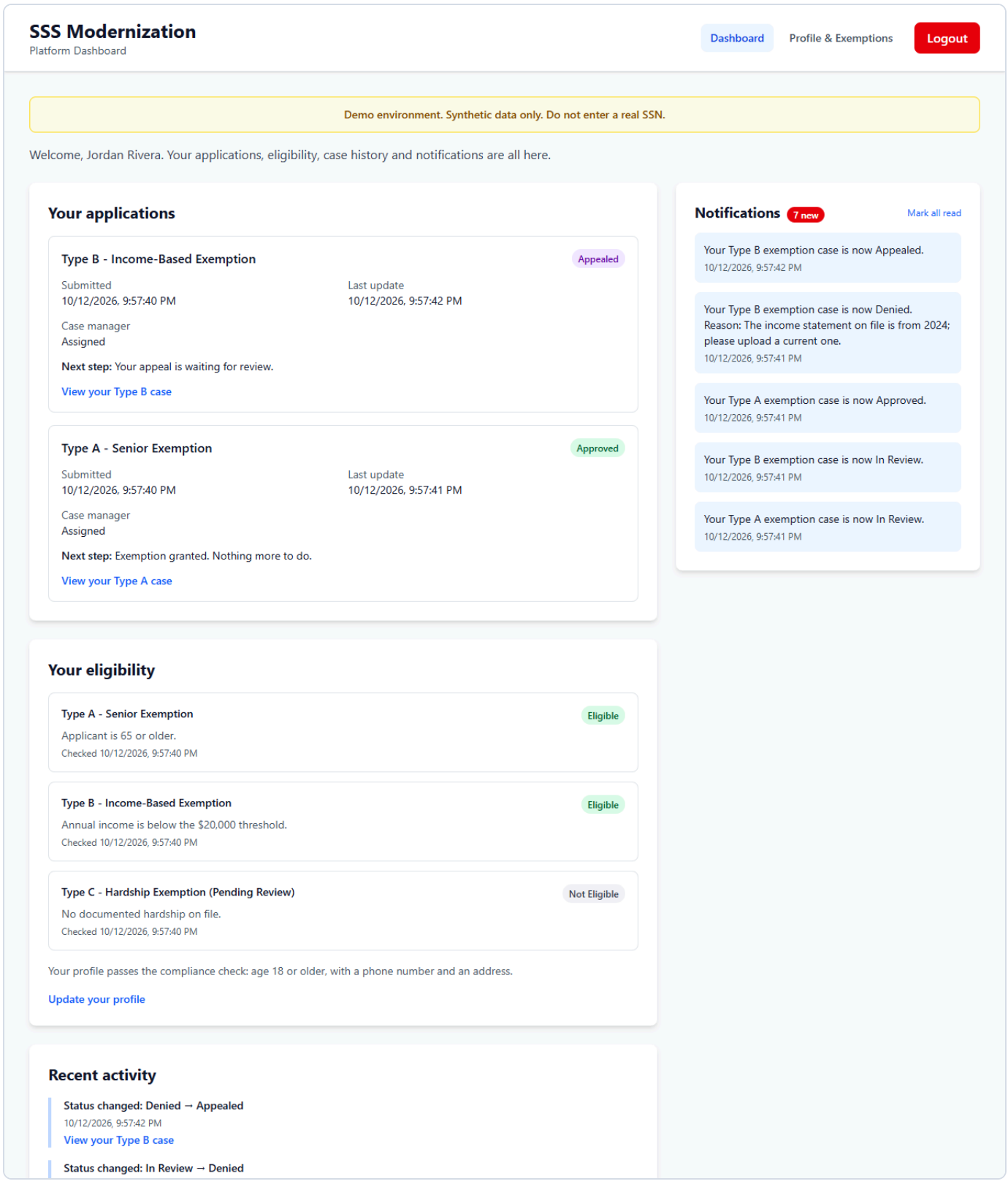


The audit log filtered to failures: the two controls the first decision missed.

SCENE 8 ·

The applicant sees everything in one place

- The dashboard lists each application with its status and the next step, the eligibility result for each exemption with its reason, the latest events across all cases, and notifications.
- Applicants never see internal notes, assignments or compliance details; the dashboard and the case page share one rule for what an applicant may see.

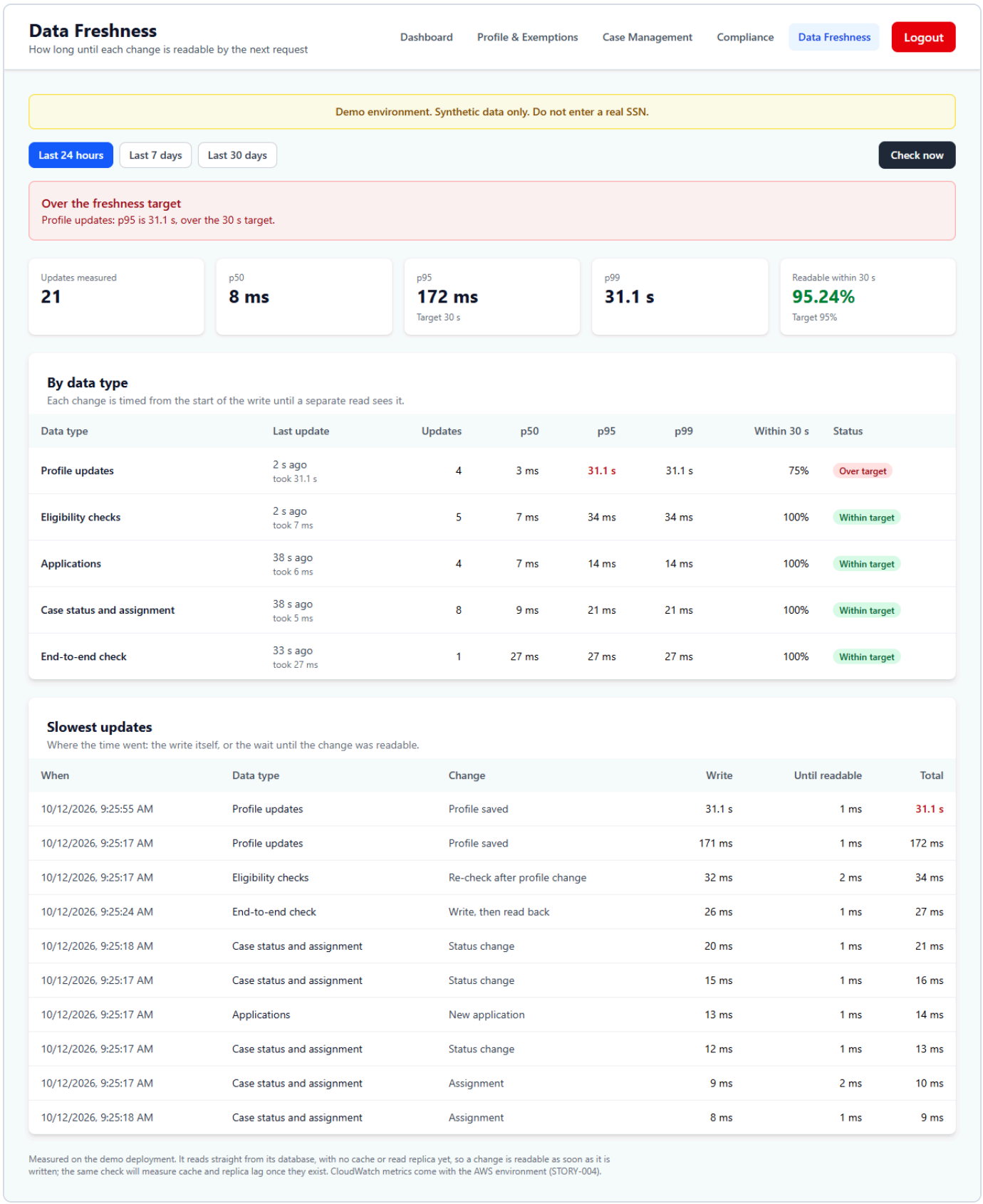


Jordan Rivera's dashboard: Type A approved, Type B appealed after a denial, each with its next step, and eligibility with reasons.

SCENE 9 ·

Every change is timed until it is readable

- Each profile save, eligibility check, application and case change is timed from the start of the write until a separate read sees it, the way the next request would.
- The target is 30 seconds for 95% of updates. Here one profile save waited 31 seconds on a database row held locked by another transaction, so profile updates went over target and the page raised the alert. The slowest-updates list shows the time went into the write.
- Check now times a write end to end from the browser and separates server time from network time.

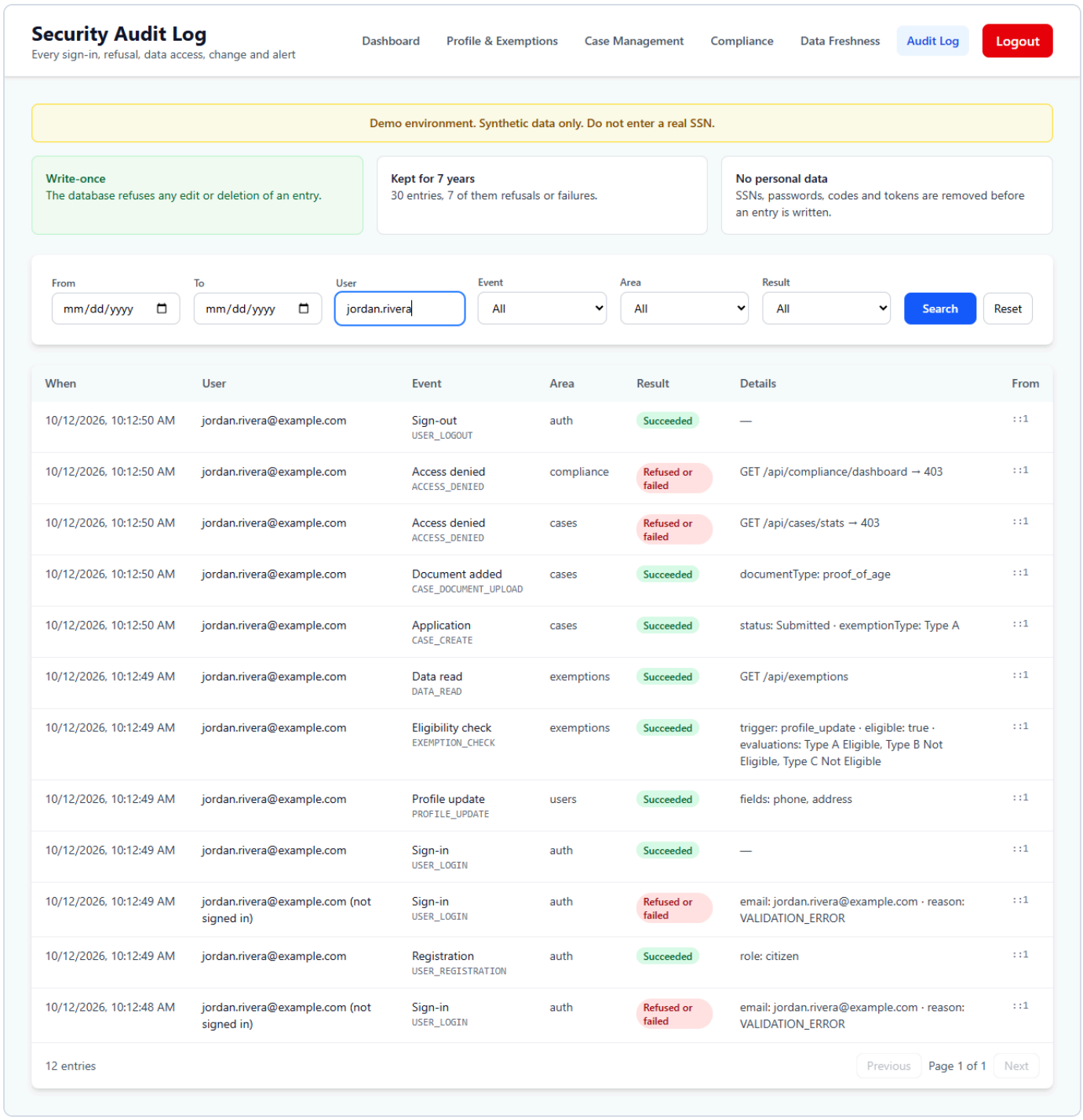


After a real slowdown: profile updates' p95 is 31.1 s, over the 30 s target; every other data type is measured in milliseconds.

SCENE 10 ·

Every security event is on the record

- Sign-ins, including failed ones filed under the address tried, sign-outs, refusals, reads, exports, profile changes, decisions, role grants, deployments and configuration changes, each with who, when and from where.
- The database refuses to edit or delete an entry, even for its owner, and keeps each one seven years. SSNs, passwords, codes and secrets never enter the log; a profile change lists the fields, not the values.



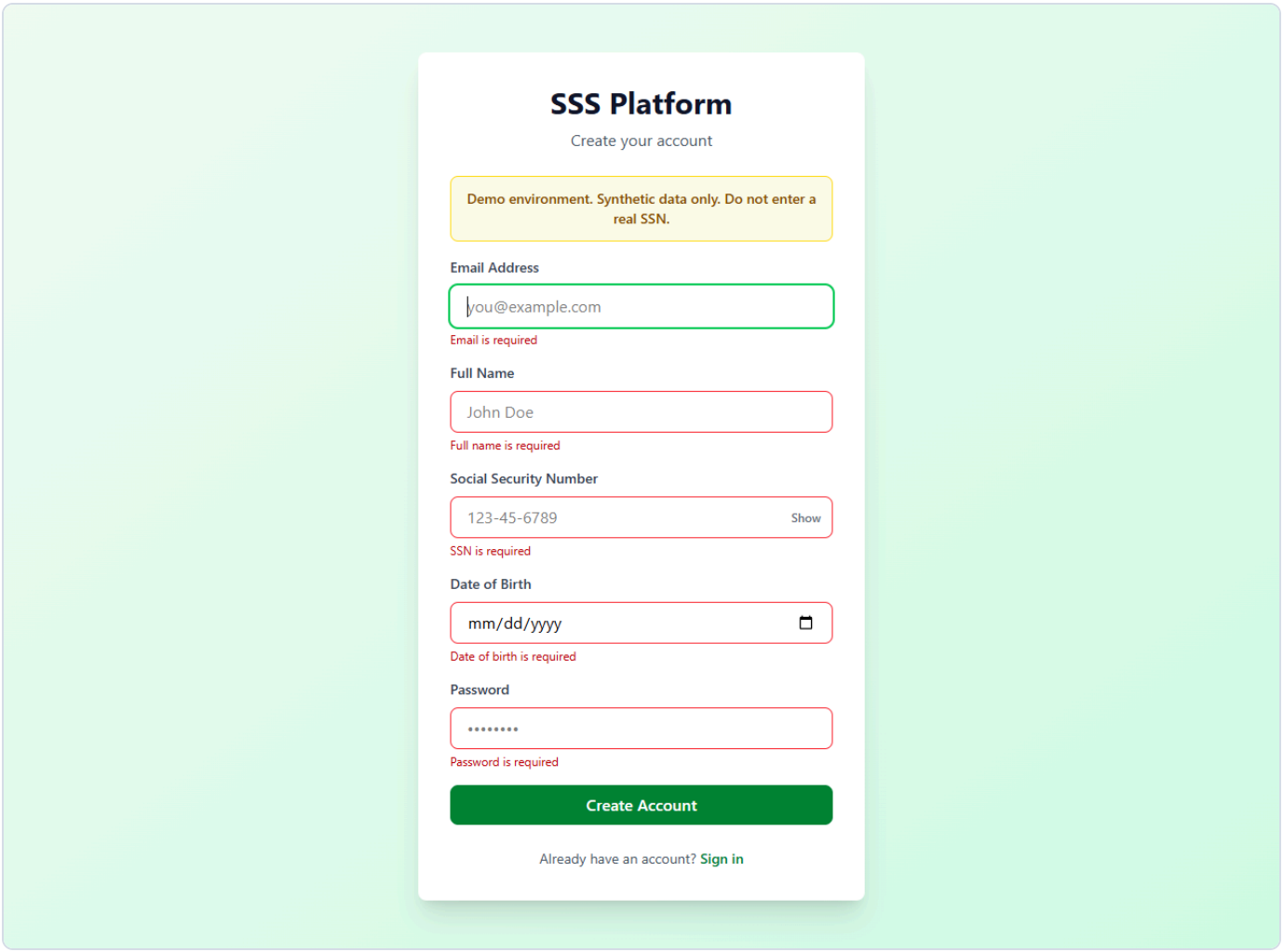
Jordan Rivera's whole trail, newest first: refused staff pages, the application, a profile change that names fields but not values, and two refused sign-ins filed under the address tried.

SCENE 11 ·

Everyone can use it

- Every page works from the keyboard. The first Tab offers Skip to main content, and focus is always visible.

- Screen readers hear each field by its name; after a failed submit each field is marked invalid with its message, and focus moves to the first. Two minutes before a session ends, a warning offers Stay signed in.
- An automated audit checks every page against WCAG 2.1 AA in Chrome. Run on the code

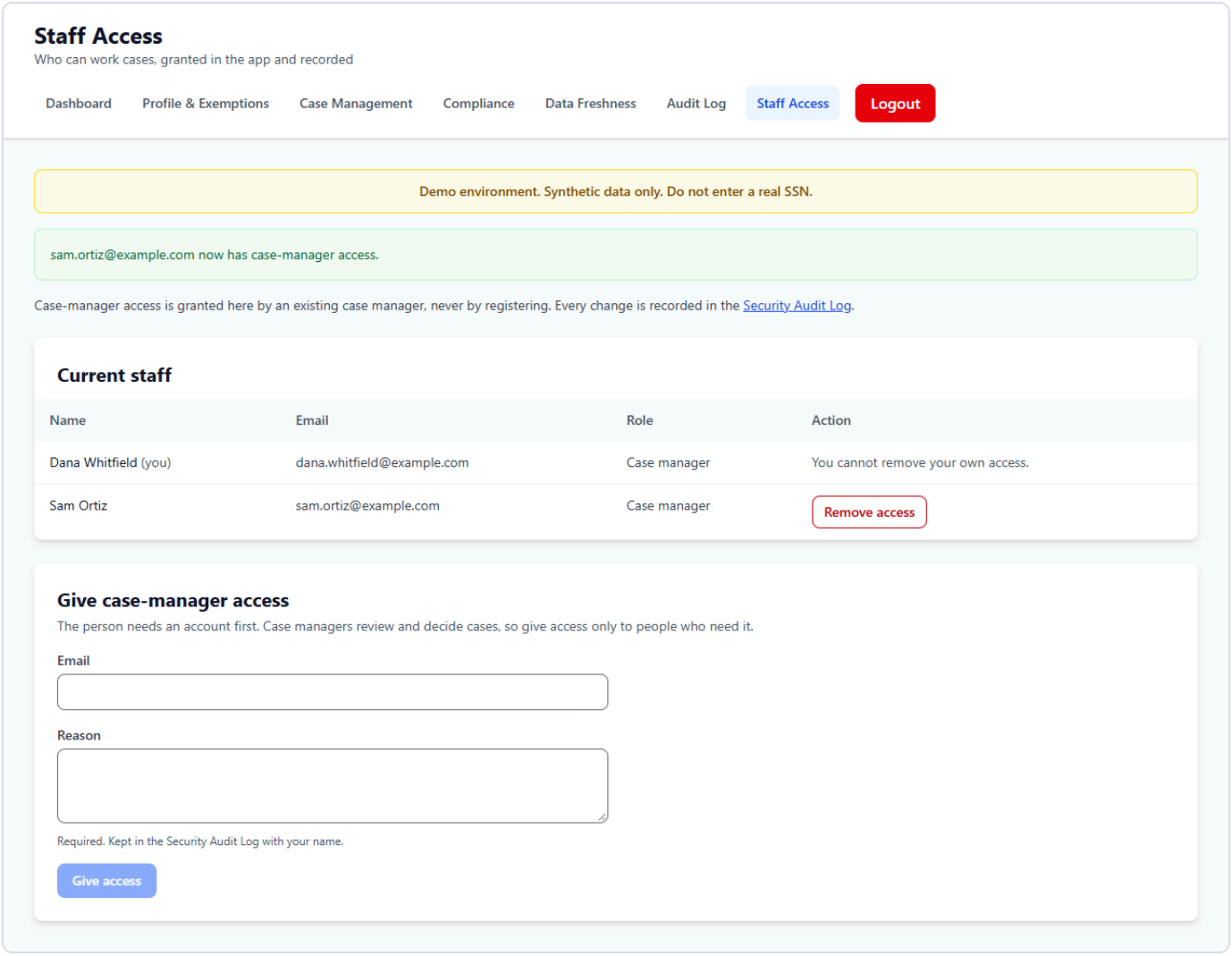


Registration after an empty submit: each field is marked invalid and described by its message, and focus is on the first one.

SCENE 12 ·

Staff access is granted, never claimed

- Access is given in the app, with a required reason, by an existing case manager (case-manager access only) or an administrator (any staff role). Registering an address no longer makes anyone staff.
- Nobody can remove their own access, the last case manager's or the last administrator's. Every change is recorded in the Security Audit Log, and the person is notified.

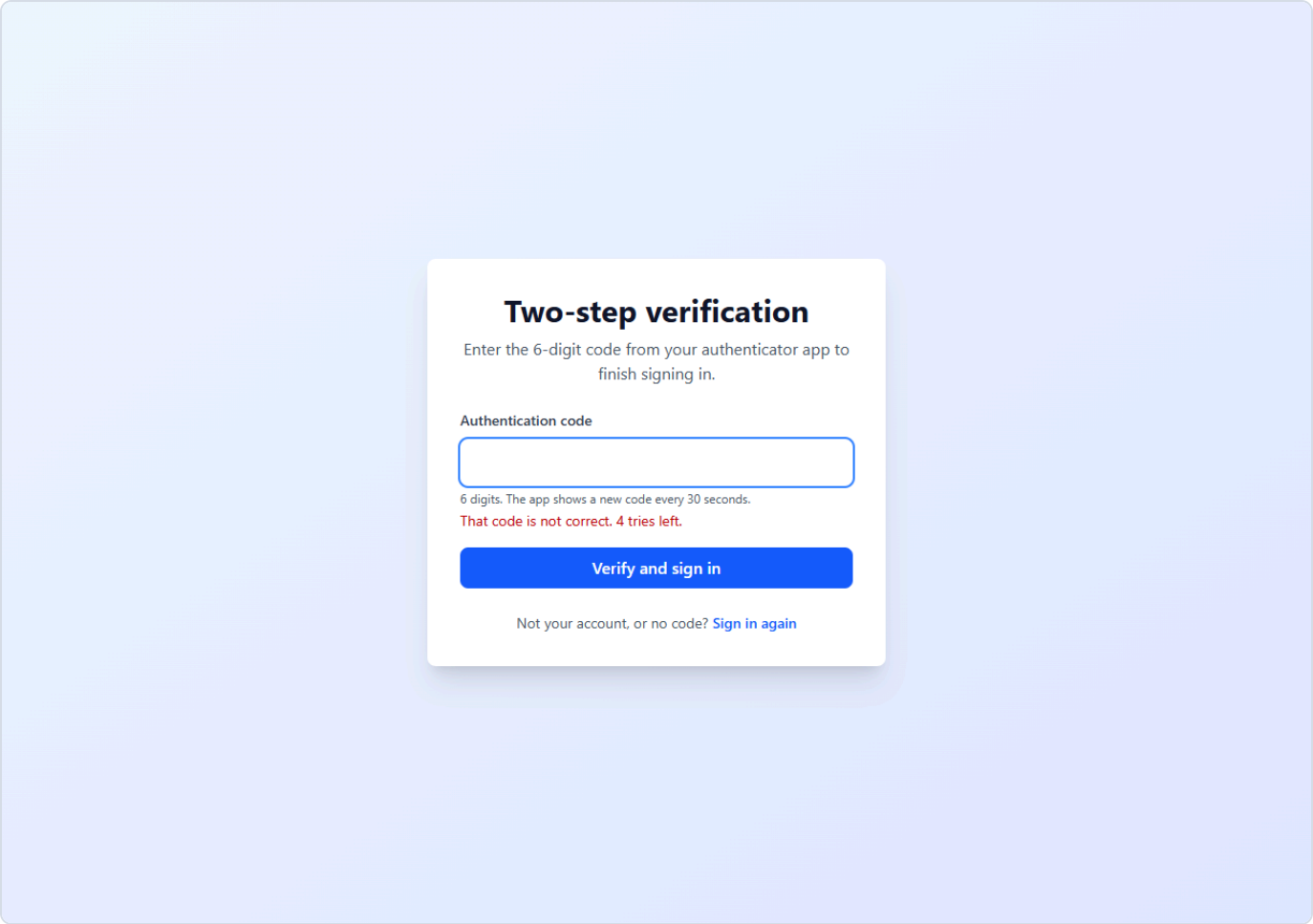


Dana Whitfield has given Sam Ortiz case-manager access, with a reason; the change is in the audit log.

SCENE 13 ·

Sign-in asks for a second step

- Under Sign-in security, a person scans a QR code with an authenticator app (Google Authenticator, Authy or Microsoft Authenticator) or types the key. The key is shown once.
- After the password, the person gets a pending sign-in that every page and route refuses, and has five minutes to enter the 6-digit code. A code works once, five wrong tries end the sign-in, and turning the second step off needs a code.
- Every step is in the audit log without the key or the code. Our own review found a pending sign-in could be redeemed twice; it is now single use, and an end-to-end check that reproduced the gap failed on the old code.



A wrong code is refused and the page shows the tries left.

SCENE 14 ·

A case manager's day starts with their work list

- My Work shows the manager's open cases, what is waiting on them (cases to start, cases to decide, compliance reviews of other managers' decisions), the unassigned queue and anything overdue, meaning no update for more than 5 days.
- Recent decisions are listed below. A search opens the case list already filtered, with the filters in the address so the view can be shared.

My Work

Your cases, what is waiting on you and what is overdue

Dashboard | Profile & Exemptions | Sign-in security | Case Management | Compliance | Data Freshness | Audit Log | Staff Access | Logout

Demo environment. Synthetic data only. Do not enter a real SSN.

Welcome, Dana Whitfield. Here is the work assigned to you, and what the team has yet to pick up.

My open cases	Waiting on me	Overdue: no update for more than 5 days	Unassigned queue
4	5	2	2
	1 to start, 3 to decide, 1 to resolve	Mine and unassigned	

Waiting on me

Cases assigned to you that need your next step, and decisions of other case managers that you may review.

Submitted cases to start (1)

Applicant	Exemption	Status	Last update	
Skyler Reed	Type A	Submitted	1 day ago	Open

Cases to decide (3)

Applicant	Exemption	Status	Last update	
Jordan Rivera	Type B	Appealed	8 days ago Overdue	Open
Pat Kim	Type B	In Review	6 days ago Overdue	Open
Avery Johnson	Type A	In Review	Today	Open

Compliance reviews to resolve (1)

Quinn Davis · Type A · Approved by sam.ortiz@example.com
Failed: CTRL-07
Opened 10/14/2026, 8:06:06 AM

Review on case

Find a case

Applicant name or email

Status: All statuses

Exemption type: All types

Assigned to: Anyone

Include approved and denied cases

Search cases

Notifications

No notifications yet.

Overdue

Open cases, yours or unassigned, with no update for more than 5 days. The longest waiting first.

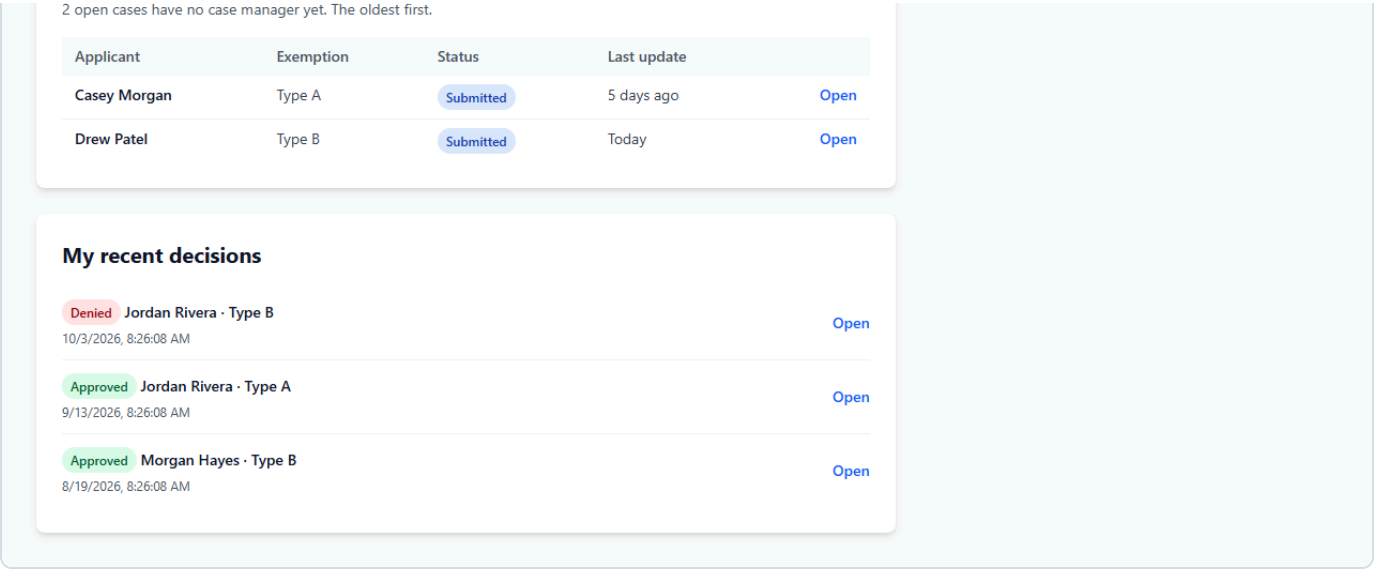
Applicant	Exemption	Status	Last update	
Jordan Rivera	Type B	Appealed	8 days ago Overdue	Open
Pat Kim	Type B	In Review	6 days ago Overdue	Open

My open cases

Assigned to you and not yet decided. The longest without an update first.

Applicant	Exemption	Status	Last update	
Jordan Rivera	Type B	Appealed	8 days ago Overdue	Open
Pat Kim	Type B	In Review	6 days ago Overdue	Open
Skyler Reed	Type A	Submitted	1 day ago	Open
Avery Johnson	Type A	In Review	Today	Open

Unassigned queue



Dana Whitfield's work list: four open cases, five waiting on her, two overdue, two unassigned.

SCENE 15 ·

Administrators see the whole operation

- All cases by status and type in charts and tables, and team performance: open cases, decided cases, median days to decide and compliance pass rate for each case manager.
- System health sits on the same page: database and migrations, the deployed commit, freshness against 30 seconds, compliance against 99%, refusals in the last 24 hours and staff by role. Administrators also give and remove staff access, never their own and never the last administrator.

Admin Dashboard

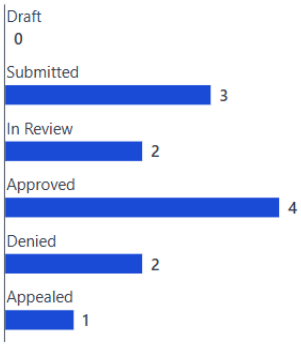
All cases, team performance and system health

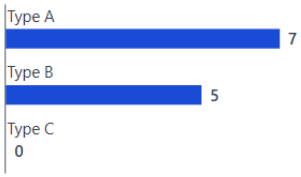
Dashboard | Profile & Exemptions | Sign-in security | My Work | Case Management | Compliance | Data Freshness | Audit Log | Staff Access | Leadership | Admin | Access Policies | Logout

Demo environment. Synthetic data only. Do not enter a real SSN.

All cases	Open cases	Decided in the last 30 days	Open compliance reviews
12	6	3	1
	Not yet approved or denied	Approvals and denials	Waiting for a second case manager

All cases





Cases by status

Status	Cases
Draft	0
Submitted	3
In Review	2
Approved	4
Denied	2
Appealed	1

Cases by exemption type

Exemption type	Cases
Type A	7
Type B	5
Type C	0

Notifications 2 new

Mark all read

You now have case-manager access, granted by dana.whitfield@example.com. Sign in again to see the staff pages.
10/14/2026, 8:06:02 AM

You now have administrator access: your address is listed for it and there was no administrator yet. Sign in again to see the admin pages.
10/14/2026, 8:06:02 AM

Team performance

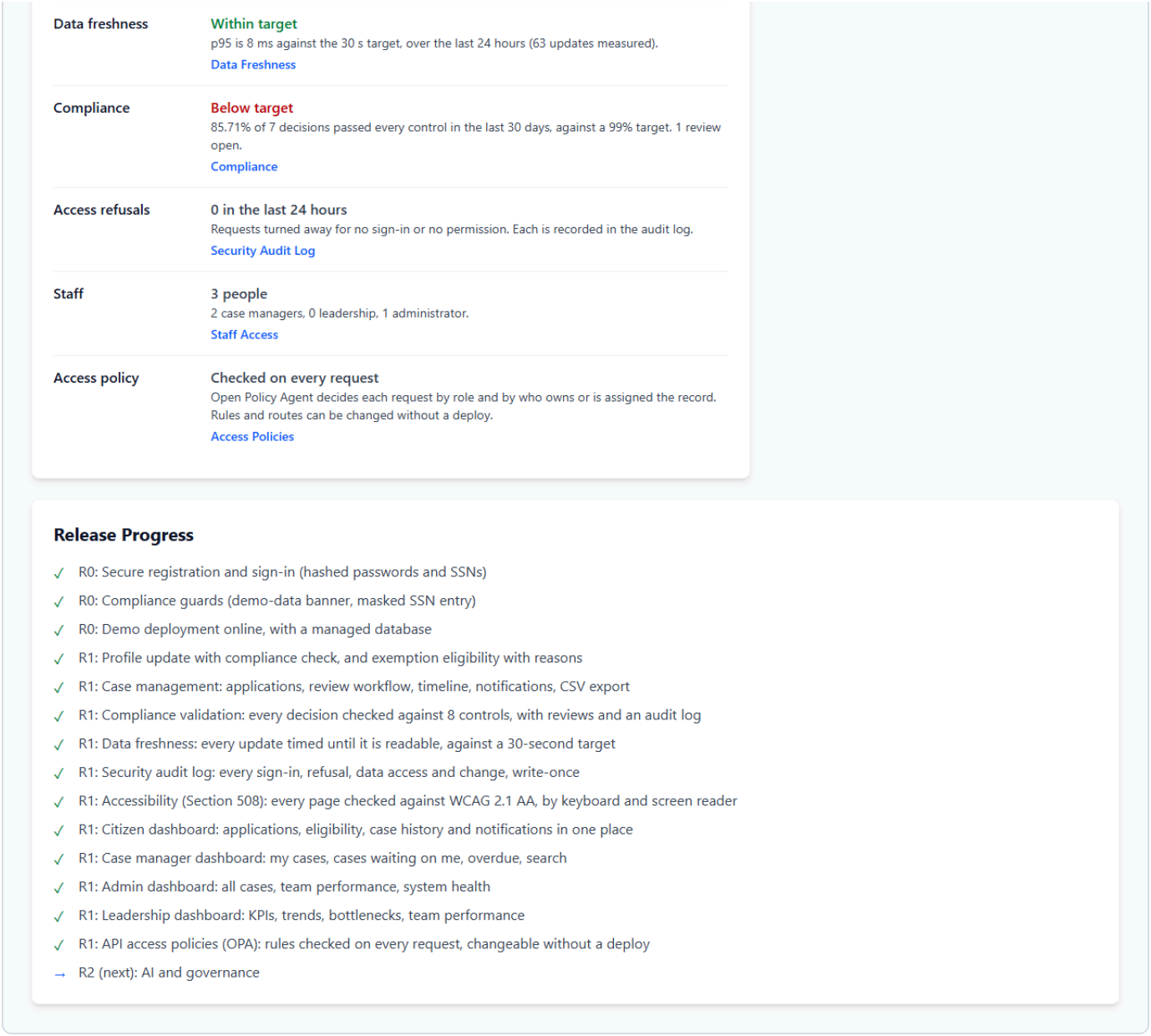
Case managers and administrators. Decisions and the figures drawn from them cover the last 30 days.

Case manager	Role	Open cases	Decided	Median days to decide	Compliance pass rate
Dana Whitfield dana.whitfield@example.com	Case manager	4	1	9	100%
Morgan Lee morgan.lee@example.com	Administrator	0	0	—	—
Sam Ortiz sam.ortiz@example.com	Case manager	0	2	7	50%

System health

Read when this page loaded.

Database	OK 19 migrations applied, the latest 019_access_policies.sql.
Release	Commit local The commit this deployment runs, as the health check reports it.



The administrator's dashboard: cases, team performance and system health in one place.

SCENE 16 ·

Leadership sees the program, not the people

- Total applications, approval rate, average processing time, open cases and appeal rate, with 12-week trends.
- Bottlenecks by stage show the average days in each and how many cases are stuck for more than 5 days. The page holds aggregates only, no applicant data, and leadership does no case work.

Leadership Dashboard

How the program is doing: totals, trends and bottlenecks

Dashboard | Profile & Exemptions | Sign-in security | Leadership | Logout

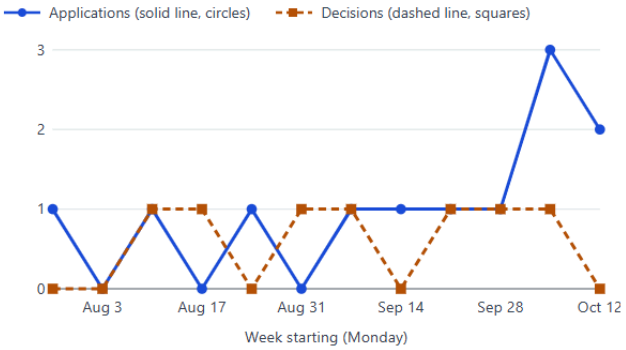
Demo environment. Synthetic data only. Do not enter a real SSN.

Counts, rates and averages across all applications. This page never shows an applicant's name, email or any other personal data.

Total applications	Approval rate	Average processing time	Open cases	Appeal rate
12	**66.67%**	**6.5 days**	**6**	**33.33%**
	4 approved of 6 decided	From submission to decision	Not yet approved or denied	1 appealed of 3 denied

Applications and decisions per week

The last 12 weeks, each starting on a Monday. A decision is an approval or a denial.



Applications and decisions per week, last 12 weeks

Week starting	Applications	Decisions
Jul 27	1	0
Aug 3	0	0
Aug 10	1	1
Aug 17	0	1
Aug 24	1	0
Aug 31	0	1
Sep 7	1	1
Sep 14	1	0
Sep 21	1	1
Sep 28	1	1
Oct 5	3	1
Oct 12	2	0

Notifications 1 new

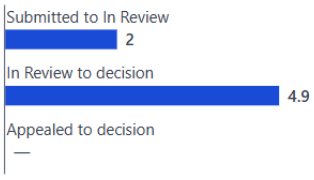
Mark all read

You now have leadership access, granted by morgan.lee@example.com. Sign in again to see the leadership dashboard.

10/14/2026, 8:06:19 AM

Bottlenecks

How long cases spend in each stage, from the case timelines, and how many are in a stage right now for more than 5 days.



Average days spent in each stage

Stage	Average days	Times measured	Stuck now (over 5 days)
Submitted to In Review	2	9	1

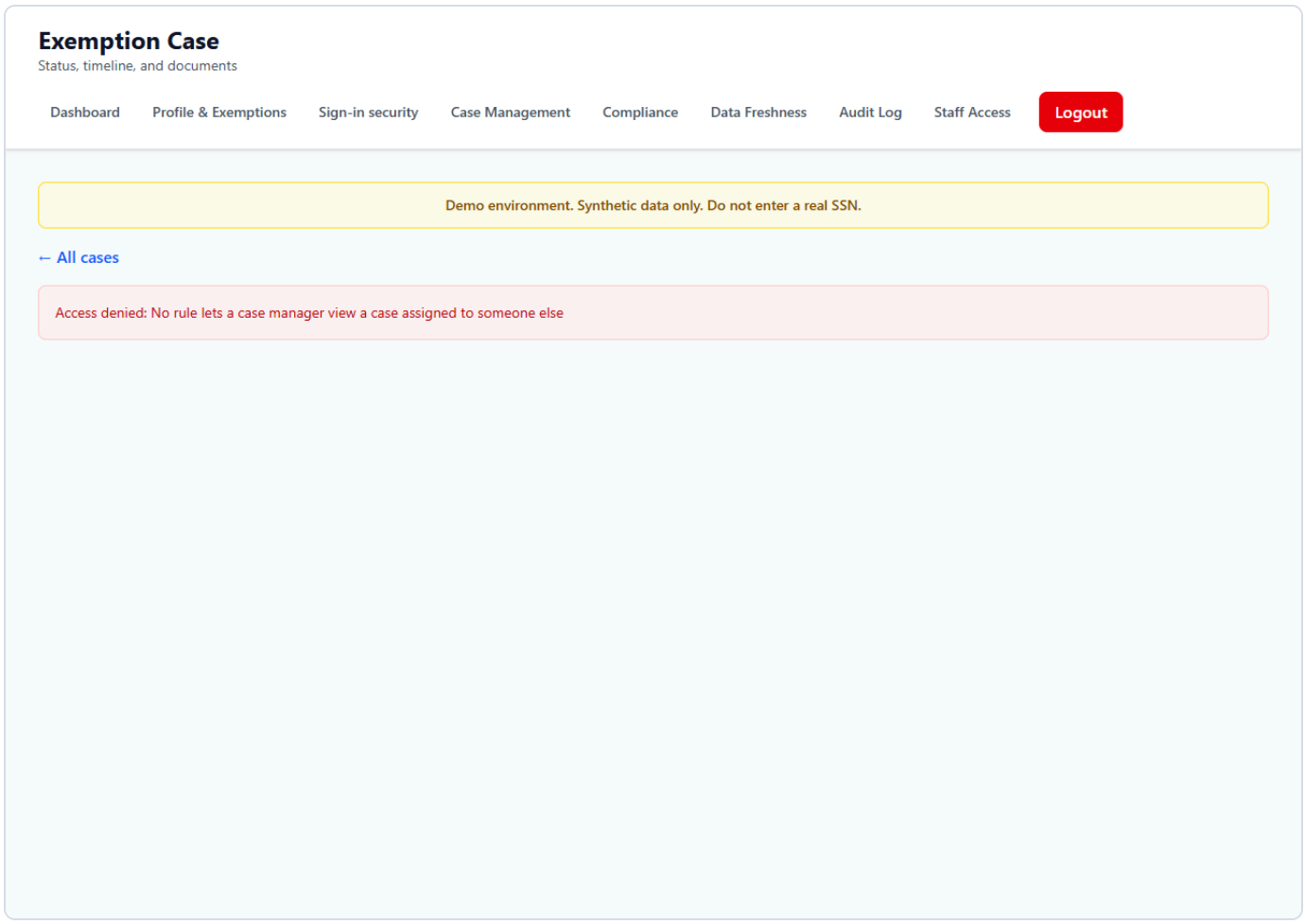


Program numbers for leadership, with no names or applicant records.

SCENE 17 ·

Access rules that change without a release

- Open Policy Agent decides every API request before any route runs, from the person's role, the kind of record, the action and who owns or is assigned the case. One rule is the story's own example: case managers can view and work cases assigned to them.
- Here a case manager opens a case assigned to someone else and is refused, with the rule named. The refusal is in the audit log with the rule and the policy version. The policy can refuse what the code allows, never allow what the code refuses.
- Administrators change the rules on an Access Policies page, without a deploy: switch a rule off or on, narrow the routes it covers, give a reason. Each version is kept and cannot be edited, each change is audited, and it applies at once. Sign-in, health and the policy pages are locked so administrators cannot lock themselves out.
- The earlier "API governance" service claimed to enforce OPA but never called it. We found that in our own archive and removed it.

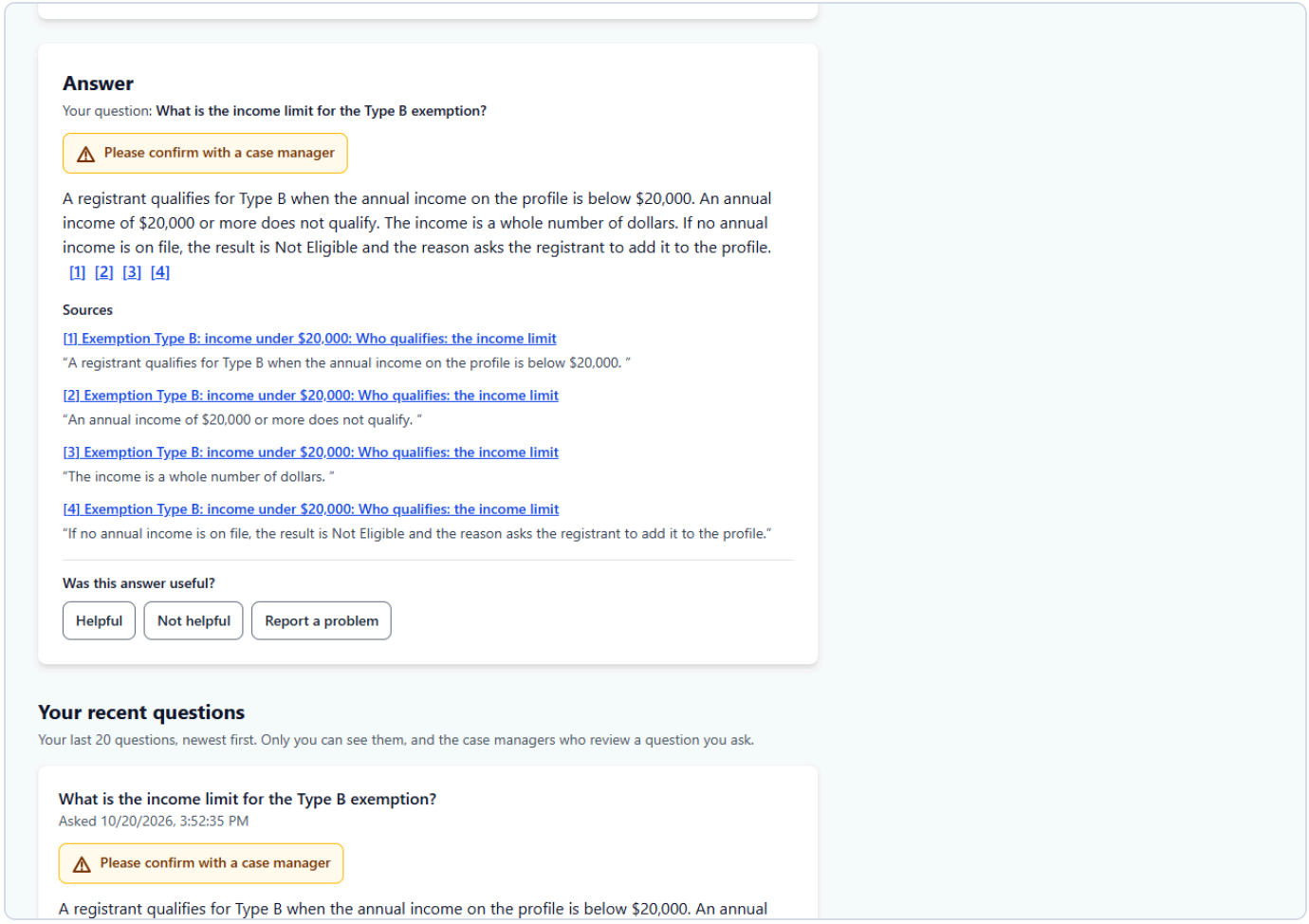


The refusal names the rule: no rule lets a case manager view a case assigned to someone else.

SCENE 18 ·

Policy answers that cite their source

- On Ask about policy, a registrant asks in plain words. Claude answers only from eight synthetic policy documents (labelled as not Selective Service policy), and every statement carries a numbered citation that opens the quoted passage.
- Before anyone sees it, a check confirms that every sentence sits under a citation and every number appears in a cited passage. An answer that fails is withheld. A thinner answer is shown with "Please confirm with a case manager". SSN-shaped text is removed before anything is searched or stored.



A live answer from Claude on the demo deployment, with four citations.

SCENE 19 ·

People decide, not the assistant

- A question about the asker's own eligibility or case, an answer that fails the check and any answer a person reports go to the Assistant Reviews queue. A case manager, never the person who asked, approves, corrects or declines, with a note for the record; the person is notified and sees the reviewed answer.
- The override rate, how often staff went against what the system said, is tracked on the admin and leadership dashboards with a 12-week trend against a 20% target.

Assistant Reviews

Answers the assistant withheld, and answers people reported

Demo environment. Synthetic data only. Do not enter a real SSN.

A case manager reviews each of these before the person sees an answer: the assistant never decides eligibility or a case on its own. You can approve the draft, correct it or decline. The person is notified, sees the result in their history marked as reviewed, and the review is recorded in the audit log. You cannot review a question you asked yourself.

Waiting for review	Longest wait	You can review
2	**0 minutes**	**2**
Withheld answers and reported problems	The one waiting longest is listed first	Not counting questions you asked yourself

Answer quality

Every answer is checked: each statement needs a citation, and each number, date or amount must appear in a cited passage. An answer that fails is withheld and waits below. The target is a failure rate below 2%.

On target: fewer than 2 in 100 answers failed the check.

Period	Answers checked	Failed the check	Failure rate	Against the 2% target
Last 7 days	2	0	0%	Under the target
Last 30 days	2	0	0%	Under the target

AI answers generated today: 2 of 300. Policy documents: 8 documents, 43 passages, version 7583e1085a63.

Waiting for review

Oldest first, by when each entered the queue (an answer that was reported counts from the report).

What is the income limit for the Type B exemption? (1792412503870)

Asked by Avery Lane (avery.lane.1792412503870@example.com). In the queue since 10/19/2026, 7:22:02 AM (waiting 0 minutes).

Why it is here

- The person reported a problem with the answer they were shown.

They wrote: “It does not say what happens at exactly $20,000.”

The answer they were shown

Type B is the income-based exemption for low-income registrants. A registrant qualifies for Type B when the annual income on the profile is below $20,000.

Drafted by the test stand-in. No AI model was called.

Grounding check: passed. 100% of the answer sits under a citation.

Citations in the draft

[1] Exemption Type B: income under $20,000

“Type B is the income-based exemption for low-income registrants.”

[2] Exemption Type B: income under $20,000: Who qualifies: the income limit

“A registrant qualifies for Type B when the annual income on the profile is below $20,000.”

Your review

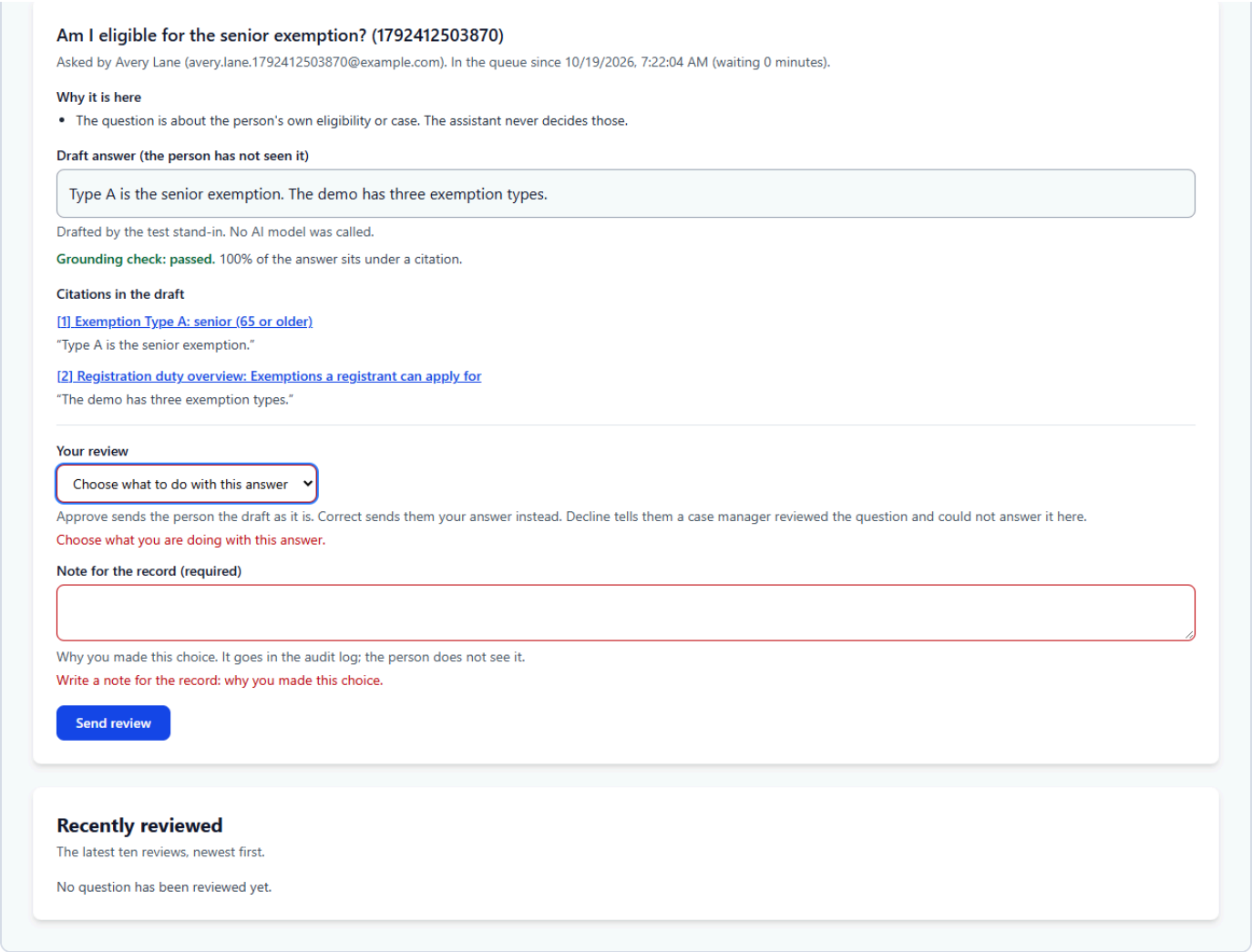
Choose what to do with this answer

Approve sends the person the draft as it is. Correct sends them your answer instead. Decline tells them a case manager reviewed the question and could not answer it here.

Note for the record (required)

Why you made this choice. It goes in the audit log; the person does not see it.

Send review

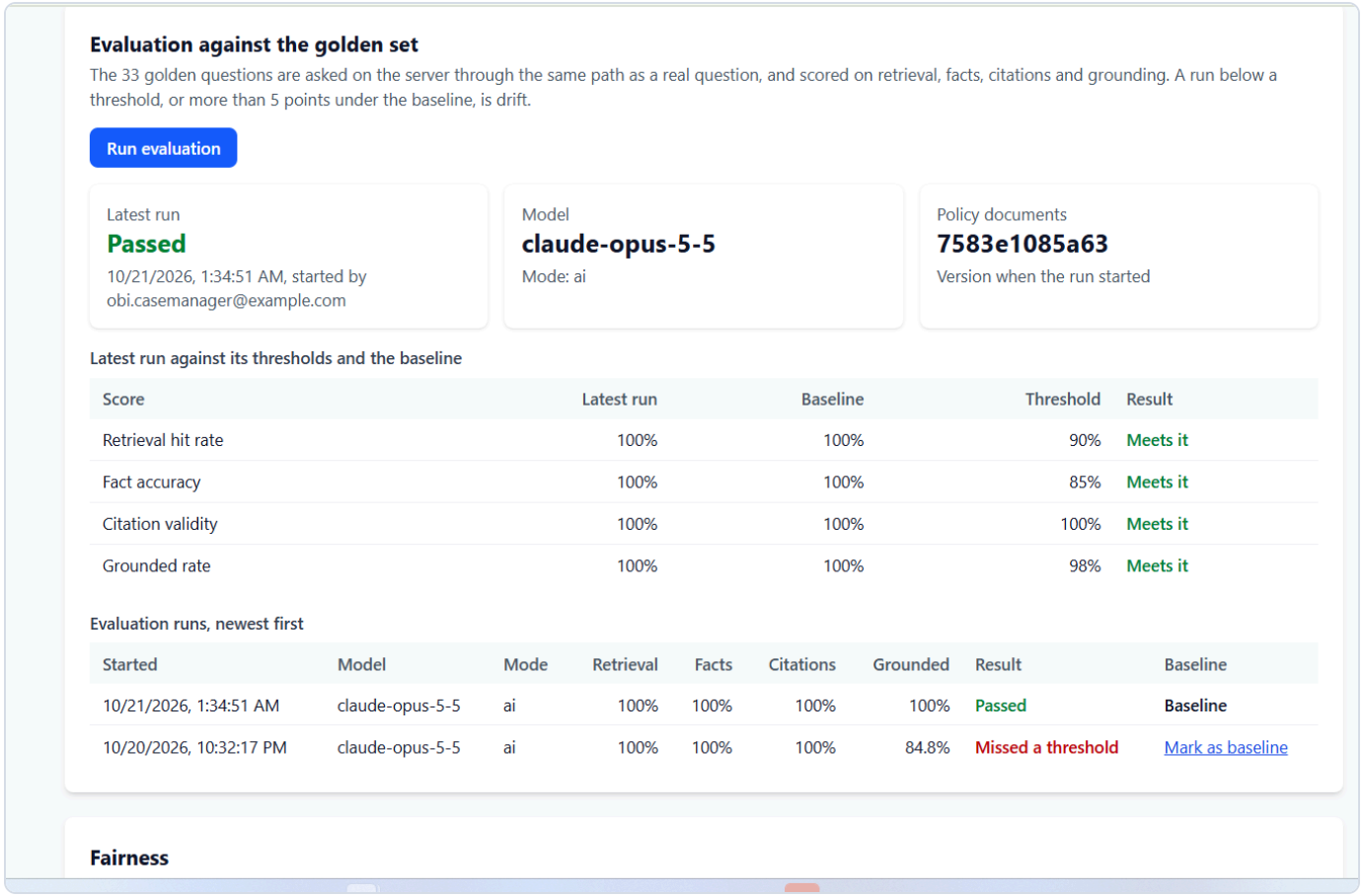


The review queue: answer quality against its target, then the questions waiting for a case manager.

SCENE 20 ·

Quality is watched after go-live

- The AI Quality page tracks nine signals from real answers, such as the grounded rate, withheld answers, latency and negative feedback, comparing the last seven days with the 28 before. A change of model or policy documents is marked on the trend.
- An administrator can re-run the 33-question golden set on the server and mark a run as the baseline. A run below a threshold, or more than 5 points under the baseline, alerts the administrators.
- The first run on the demo deployment failed: some answers opened with an uncited sentence of the model's own, which the check rightly withheld. The model's instructions were fixed, and the re-run scored 100% on retrieval, facts, citations and grounding.

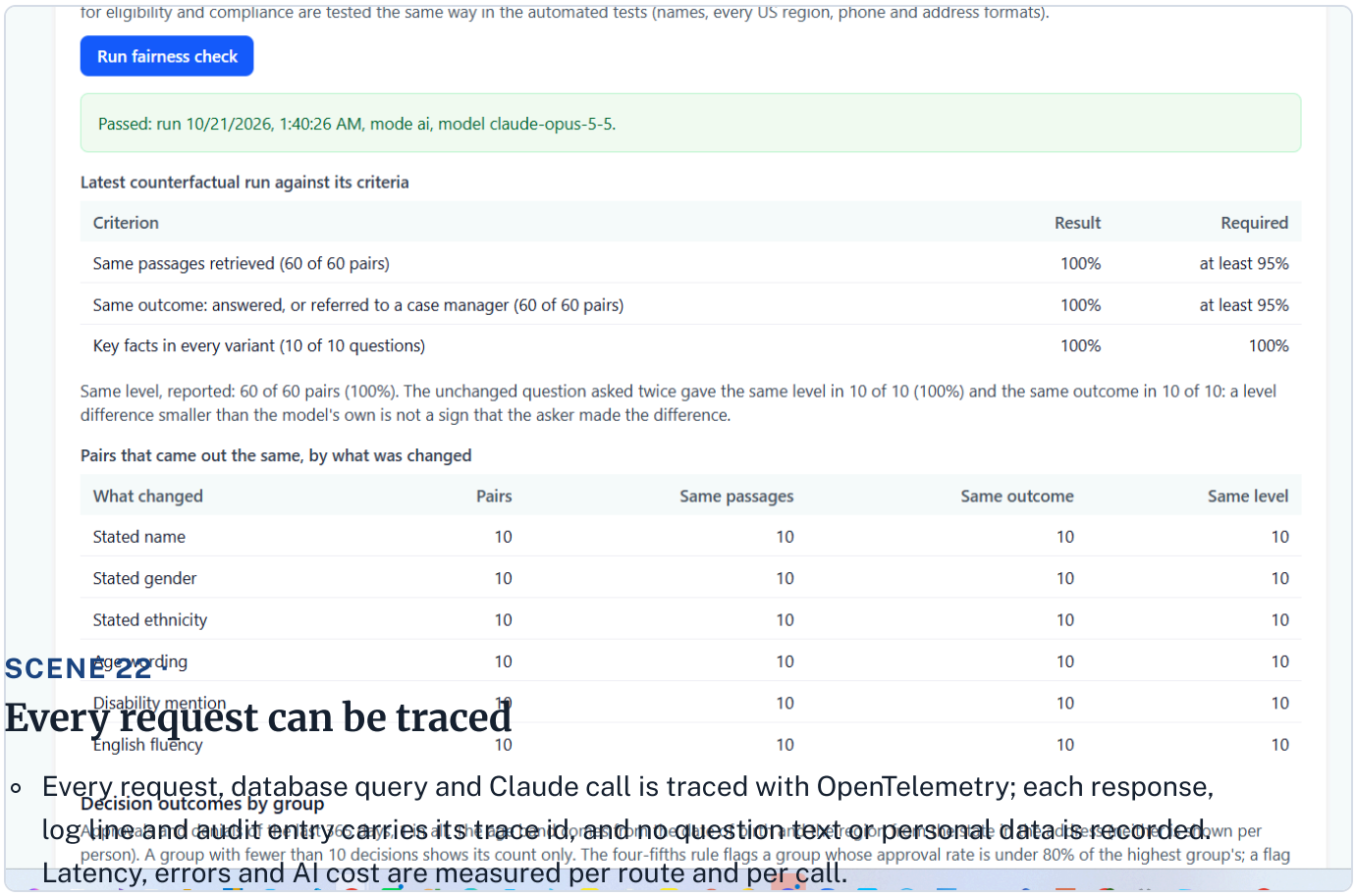


The real run on the demo deployment, now the baseline.

SCENE 21 ·

Who asks must not change the answer

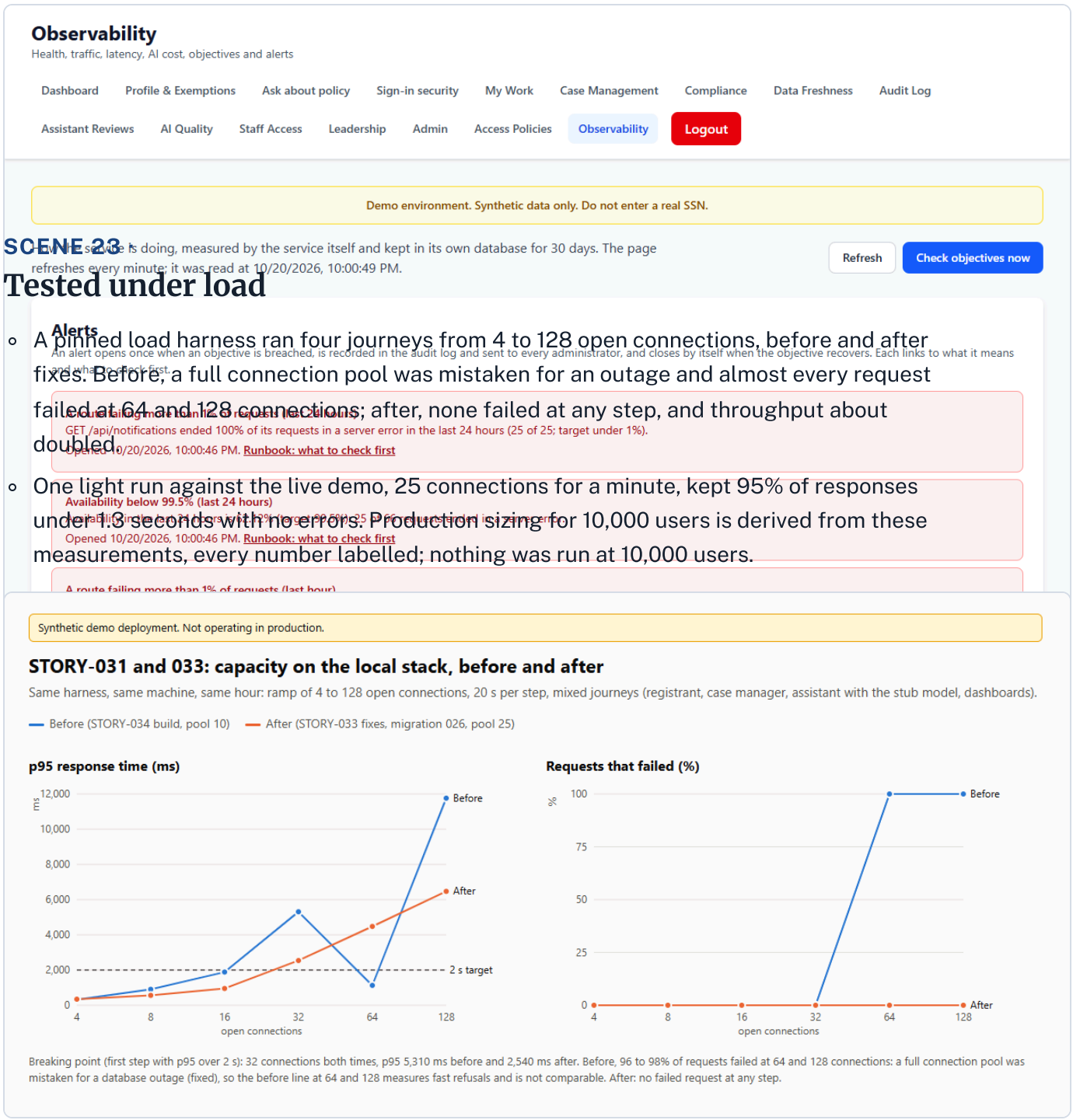
- The demo collects no race, sex, ethnicity, religion, disability or national origin. Fairness is tested by changing only a detail that must not matter: 383 automated tests cover names, every US region and address formats for the decision rules.
- The assistant is asked ten questions unchanged and with a statement about the asker (a name, gender, ethnicity, age wording, disability or limited English). On the demo deployment the same passages and the same outcome came back in 60 of 60 pairs. Approval rates by age band and region are compared with the four-fifths rule.



SCENE 22

Every request can be traced

- Every request, database query and Claude call is traced with OpenTelemetry; each response, log line and audit entry carries its trace id, and no question text or personal data is recorded. Latency, errors and AI cost are measured per route and per call.
- Objectives (availability 99.5%, 95% of requests under 2 seconds, errors under 1%, AI spend under budget, plus drift and fairness) are checked every minute; a breach opens an alert with a runbook entry. Export to Datadog or any OpenTelemetry backend is one setting.



The same harness, machine and hour, before and after the performance fixes.

SCENE 23 ·

Tested under load

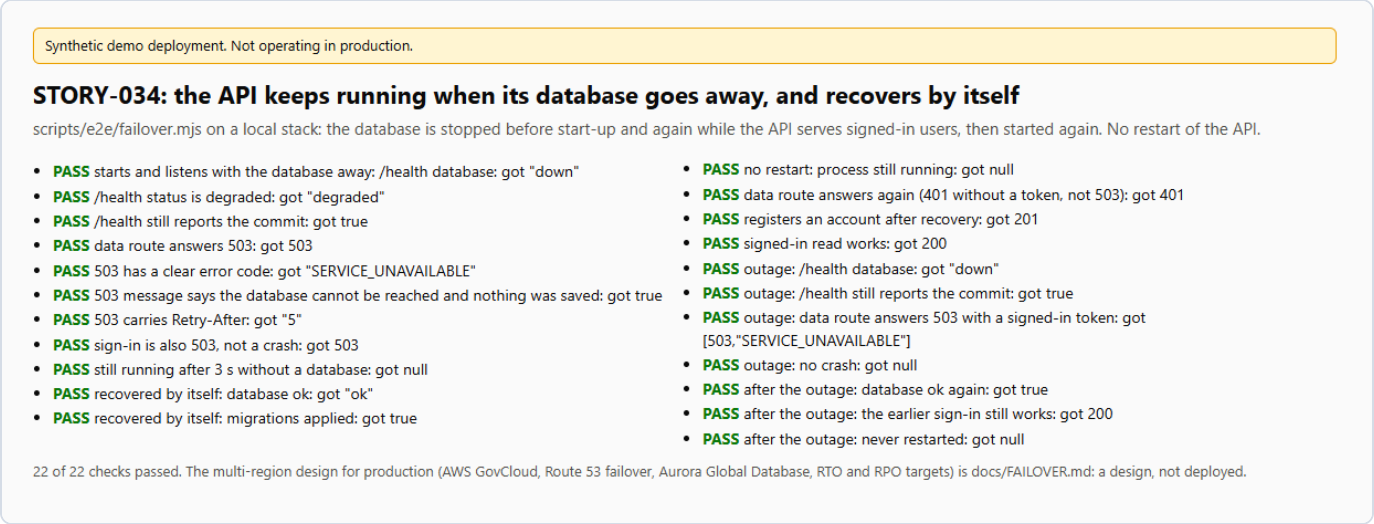
- A pinned load harness ran four journeys from 4 to 128 open connections, before and after fixes. Before, a full connection pool was mistaken for an outage and almost every request failed at 64 and 128 connections; after, none failed at any step, and throughput about doubled.
- One light run against the live demo, 25 connections for a minute, kept 95% of responses under 1.3 seconds with no errors. Production sizing for 10,000 users is derived from these measurements, every number labelled; nothing was run at 10,000 users.

SCENE 24 ·

It stays up when the database goes away

- If the database is unreachable the API keeps running, answers every data request with a clear "try again" and saves nothing half way, and recovers by itself when the database returns, without a restart (22 of 22 checks).
- An uptime check outside the hosting platform runs every 30 minutes and opens an issue on

failure. The multi-region production design is written and waits on approval.

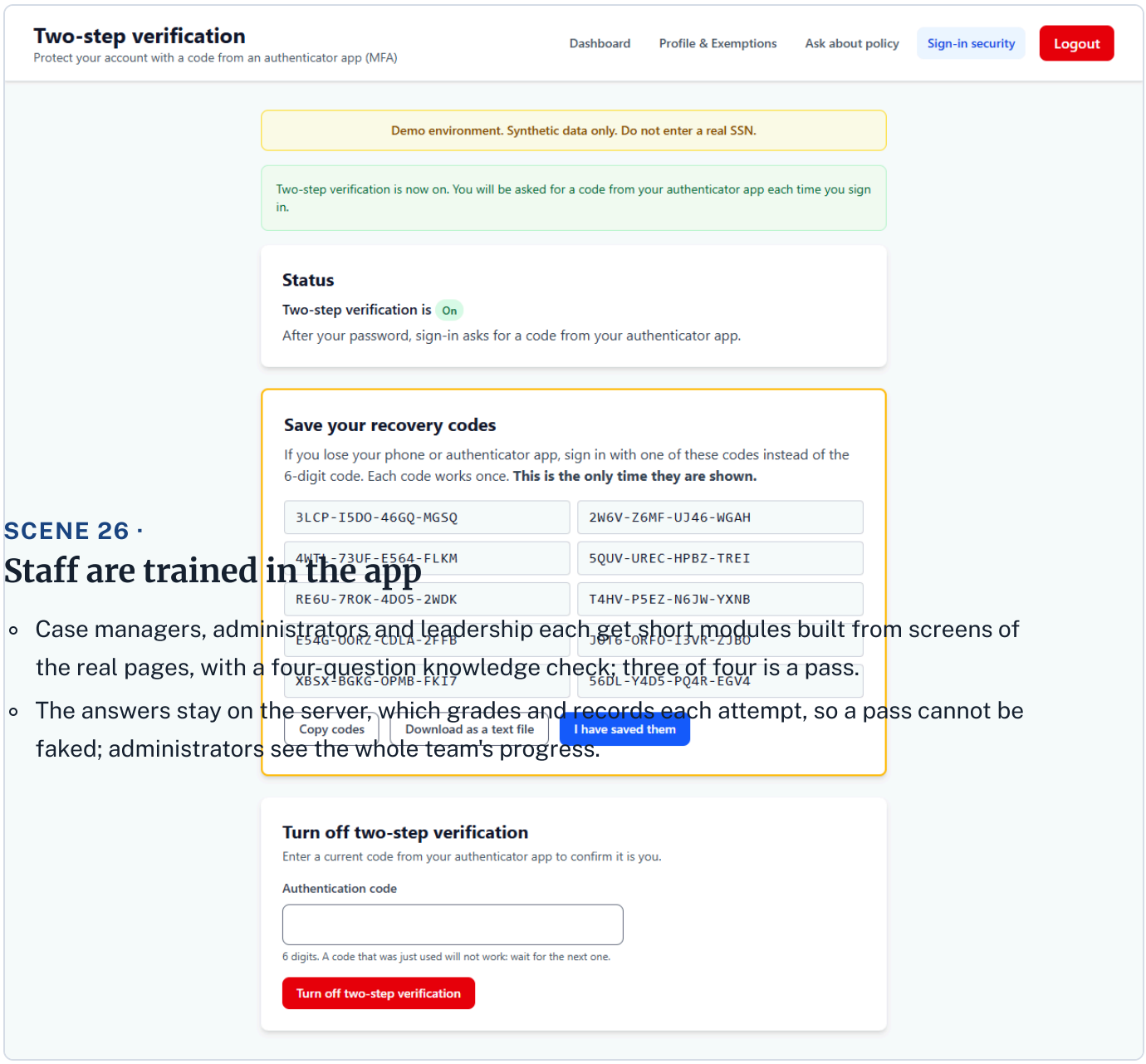


The outage drill on a local copy: the database stopped before start-up and while serving.

SCENE 25 ·

Sign-in hardened and tested

- An attack suite of 52 checks tries sign-in bypass, other people's records, injection and password guessing, and checks the security headers; all pass. Signing out ends the session on the server, sign-in is throttled and every page carries a content security policy.
- Two-step verification now comes with ten one-time recovery codes for a lost phone, shown once. This is the team's own testing; an independent penetration test is still owed.

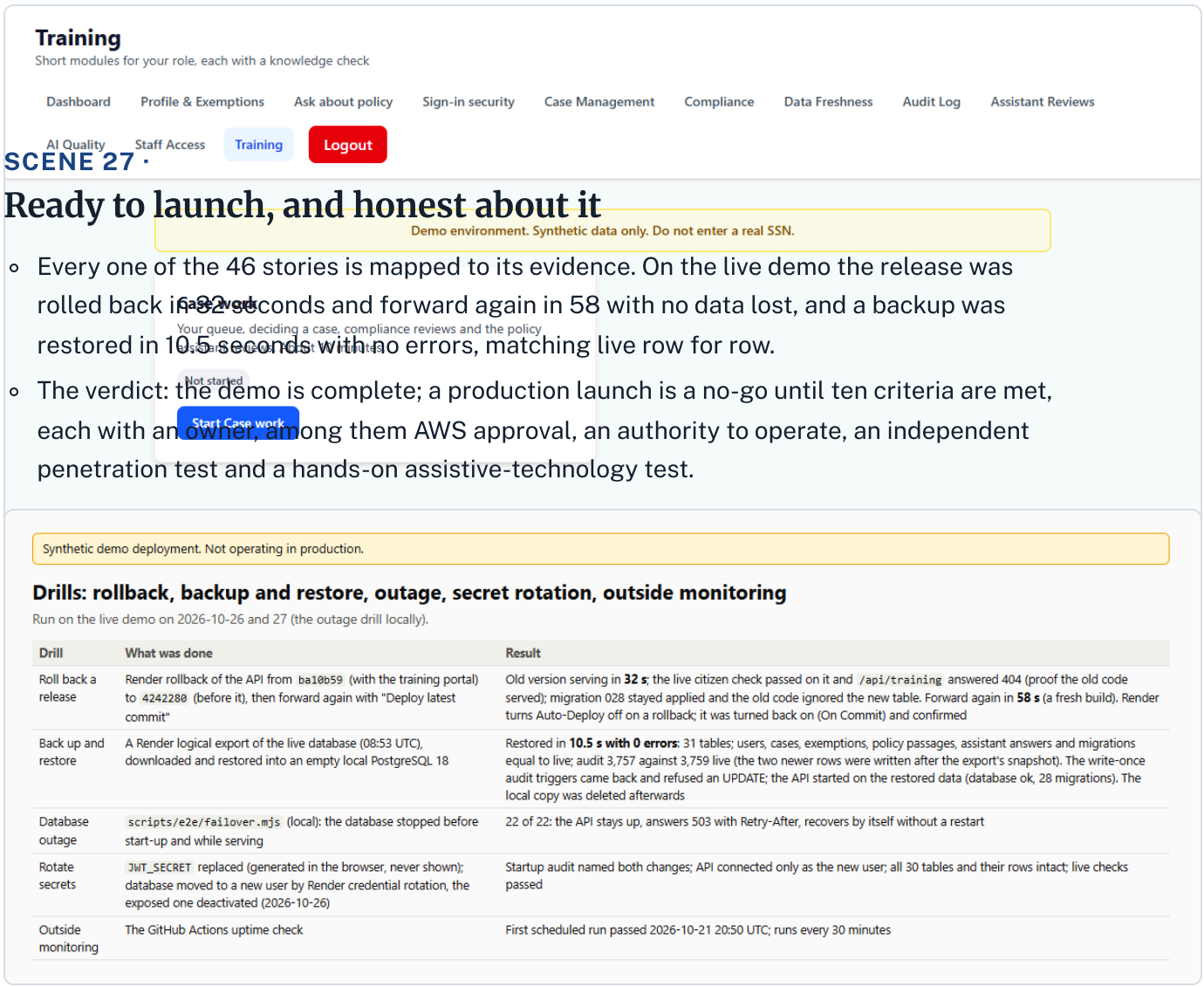


Recovery codes appear once, when two-step verification is turned on.

SCENE 26 ·

Staff are trained in the app

- Case managers, administrators and leadership each get short modules built from screens of the real pages, with a four-question knowledge check; three of four is a pass.
- The answers stay on the server, which grades and records each attempt, so a pass cannot be faked; administrators see the whole team's progress.



Drills run on the live demo on October 26 and 27.

SCENE 27 ·

Ready to launch, and honest about it

- Every one of the 46 stories is mapped to its evidence. On the live demo the release was rolled back in 32 seconds and forward again in 58 with no data lost, and a backup was restored in 10.5 seconds with no errors, matching live row for row.
- The verdict: the demo is complete; a production launch is a no-go until ten criteria are met, each with an owner, among them AWS approval, an authority to operate, an independent penetration test and a hands-on assistive-technology test.

DECISION CONTROLS

What every decision is checked against

Control	What is checked	Basis	Applies to
CTRL-01	The approval matches a current Eligible or Pending Review determination	Program eligibility rules	Approvals
CTRL-02	Eligibility was re-checked after the applicant's last profile change	Privacy Act, 5 U.S.C. 552a(e)(5): accurate, timely records	All decisions
CTRL-03	A denial records its reason and the applicant is notified	Administrative Procedure Act, 5 U.S.C. 555(e)	Denials
CTRL-04	The person deciding is not the applicant	NIST SP 800-53 AC-5, separation of duties	All decisions
CTRL-05	The case is assigned to the case manager who decides it	Program policy: an accountable reviewer	All decisions
CTRL-06	The decision is made from In Review	Program policy: review before decision	All decisions
CTRL-07	The required document is on file: proof of age, income statement or hardship evidence	Program policy: supporting evidence	Approvals
CTRL-08	The decision is in the audit log with who, what and when	NIST SP 800-53 AU-3, audit record content	All decisions

SECURITY AND TRUST

Built to be checked

- **Protected identity data.** Passwords and SSNs are stored as bcrypt hashes. The SSN is never returned by the API, never written to logs and left out of every export.
- **Access decided per endpoint.** Each route declares whether it is public, for signed-in users, for the record's owner or for staff. A test fails the build when a route is missing its rule or its check.

- **Separation of duties.** Case managers cannot decide their own cases or clear reviews of their own decisions.
- **Staff access granted, not claimed.** Access is given in the app, with a reason, by an existing case manager or an administrator, never by registering an address; nobody can change their own access, and every change is in the audit log.
- **Two steps to sign in.** An authenticator app supplies a 6-digit code after the password. The pending sign-in is refused everywhere, each code works once, and the key and codes never enter the log.
- **A policy decides every request.** Open Policy Agent, compiled to WebAssembly inside the API, decides each request before any route and can only narrow what the code allows. Administrators change the rules without a deploy, and every version, change and refusal is on the record.
- **AI under human control.** The assistant answers only from the policy, cites every statement and is checked before an answer is shown; it never decides a case. It is re-tested against a baseline, tested for fairness, and every call is traced with its cost.
- **Watched in operation.** Every request carries a trace id; service objectives are checked every minute, and a breach alerts the administrators with a runbook entry.
- **Accessible by design.** Every page is checked against WCAG 2.1 AA (Section 508) for each kind of user: keyboard, screen-reader names and errors, contrast, reflow at 320 pixels, a session warning, and confirmation before an application is sent.
- **Write-once audit trail.** Every sign-in, refusal, data read, export, change, role grant, deployment and configuration change is recorded with who, when and from where, alongside every compliance result. The database refuses edits and deletions, entries are kept seven years, and no SSN, password or secret is written to the log.
- **Tested like an attacker would.** A 52-check attack suite runs against every release candidate: sign-in bypass, token tampering, other people's records, injection, guessing. Sign-out ends sessions on the server, sign-in is throttled, and secrets shared during the build were rotated.
- **Built to recover.** The API survives its database going away and recovers by itself; releases roll back in under a minute; backups are restored and checked row for row.
- **Verified releases.** After each deploy the team checks the demo deployment automatically: the running version, the database, all protected routes refusing anonymous requests, and every staff route refusing an ordinary registrant. Each story ships with screenshots and a written conclusion.

STATUS AND ROADMAP

46 stories in four releases

R0 · Walking skeleton

4 of 5 in the demo, 1 written

Secure registration and sign-in, profile and compliance check, two-step verification, and the data status card. The AWS GovCloud infrastructure is written as code and checked, waiting on approval to be applied.

R1 · Core services

11 of 11 in the demo (complete)

In the demo: exemption eligibility, case management, compliance validation, data freshness, security audit logging, accessibility (Section 508), the citizen, case manager, admin and leadership dashboards, and API access policies with Open Policy Agent.

R2 · AI and governance

11 of 11 in the demo (complete)

In the demo: policy answers from Claude with cited sources, hallucination and drift monitoring, human-in-the-loop review, override tracking, fairness testing and observability. The real-model evaluation and fairness runs passed on the demo deployment on October 21.

R3 · Scale and launch

17 of 17 done (complete)

Load testing and production sizing, surviving a database outage, monitoring from outside, security testing and hardening, staff training, the incident playbook, runbooks and guides, the accessibility conformance report, and a readiness review with live rollback and restore drills. Production go-live is a no-go until ten owned criteria are met.

Colaberry's scope assessment placed current readiness at 33 out of 100 on its INPACT scale; the full program targets 86.

FOR PRESENTERS

Suggested slide outline

1. Title: SSS Modernization Demo, Colaberry, solicitation 90MC26R0004
2. Why it matters: the registry, who depends on accurate registration status
3. The problems: thirteen challenges and how the platform answers each
4. Who uses it: registrants, case managers, compliance, administrators and leadership
5. Registrant journey: account, eligibility with reasons, apply, follow the case (scenes 1, 2 and 8)
6. Case management: one queue, decisions with reasons, appeals (scenes 3 and 4)
7. Compliance by design: 8 controls on every decision, dashboard and target (scene 5 and the control table)
8. Accountability: second-manager review and the audit log (scenes 6 and 7)
9. Current data: every change timed against a 30-second target, with an alert (scene 9)
10. On the record: every sign-in, refusal, read and change in a write-once log (scene 10)
11. Everyone can use it: WCAG 2.1 AA on every page, keyboard and screen readers (scene 11)
12. Who can work cases: staff access granted in the app, never claimed (scene 12)
13. Two steps to sign in: authenticator app, one-time codes, a pending sign-in nothing accepts (scene 13)
14. Each role's view: case manager work list, administrator operations, leadership program numbers (scenes 14 to 16)
15. Access rules that change without a release: Open Policy Agent decides every request (scene 17)
16. AI with human control: cited policy answers, the review queue and the override rate (scenes 18 and 19)
17. AI watched in operation: drift against a baseline, fairness tests, tracing and alerts (scenes 20 to 22)
18. Scale and launch: load tests, outage survival, hardening, staff training, and the readiness drills (scenes 23 to 27)
19. Security and trust: protected SSNs, per-endpoint access, verified releases
20. Status and roadmap: what works in the demo today and what comes next

Prepared by Colaberry for the SSS modernization proposal. Screens come from the demo application running the code deployed at sss-demo-frontend.onrender.com, with synthetic people and records. Everything shown is demonstrated on that synthetic deployment, not operating in production. The first visit after a quiet period takes about a minute while the demo server wakes.